SK Sheldus Rookies 32

GM Shop 모의침투 결과 보고서

	시나리오 기반 GM Shop 모의해킹 결과 보고서		
	Category	문서 버전	문서 최종 수정일
	Development Report	1.1.4	2026.06.04

팀명:	**엄마는 외계인**
팀장:	**백세희**
팀원:	팀원 A
	팀원 B
	팀원 C
	팀원 D
	팀원 E
	팀원 F

Copyright ⓒ 2022 By ngnicky All Rights Reserved.

	시나리오 기반 GM Shop 모의해킹 결과 보고서		
	Category	문서 버전	문서 최종 수정일
	Development Report	1.1.4	2026.06.04

문서 정보 / 수정 내역

File Name	GM Shop 모의해킹 결과 보고서
원안작성자	팀원 C
수정작업자	

수정 날짜	대표 수정자	Revision	추가/수정 항목	내 용
2026-06-02	팀원 C	1.0	초안	초안 작성
2026-06-04	팀원 B	1.1.1	취약점,대응방안	취약점 및 대응방안 작성
2026-06-04	팀원 C	1.1.2	취약점,대응방안	취약점 및 대응방안 작성
2026-06-04	백세희	1.1.3	취약점,대응방안	취약점 및 대응방안 작성
2026-06-04	팀원 E	1.1.4	취약점,대응방안	취약점 및 대응방안 작성

Copyright ⓒ 2022 By ngnicky All Rights Reserved.

	시나리오 기반 GM Shop 모의해킹 결과 보고서		
	Category	문서 버전	문서 최종 수정일
	Development Report	1.1.4	2026.06.04

목차

1. 개요 9

1.1. 모의해킹 정의 9

1.2. 수행일정/수행내역 9

1.3. 수행 대상 및 장소 9

1.4. 수행 단계별 방법 10

1.5. 점검 항목 11

1.6. 점검 도구 12

2. 결과 요약 13

2.1. 총평 13

2.2. 취약점 요약 14

3. 상세 수행 내역 17

3.1. 에러 메시지 처리 17

3.1.1. 체크리스트 검증 17

3.2. 최신 취약점 미패치 19

3.2.1. 체크리스트 검증 19

3.3. 디렉터리 리스팅 22

3.3.1. 체크리스트 검증 22

3.4. 불필요한 파일 다운로드 24

3.4.1. 체크리스트 검증 25

3.5. 관리자 페이지 추측 및 대입 29

3.5.1. 체크리스트 검증 29

3.6. 인증 우회 31

3.6.1. 체크리스트 검증 31

3.7. 계정 정보 추측 및 대입 36

3.7.1. 체크리스트 검증 37

3.8. 파라미터 조작 39

3.8.1. 체크리스트 검증 40

3.9. XSS (XST / TRACE) 43

3.9.1. 체크리스트 검증 44

Copyright ⓒ 2022 By ngnicky All Rights Reserved.

3.10. 페이지 내 중요 정보 노출 45

3.10.1. 체크리스트 검증 45

3.11. SQL Injection 47

3.11.1. 체크리스트 검증 47

3.12. 파일 업로드 취약점 49

3.12.1. 체크리스트 검증 49

4. 취약점 대응방안 52

4.1. 에러 메시지 정보 노출 52

4.1.1. 취약점 개요 52

4.1.2. 권고사항 52

4.2. 최신 취약점 미패치 53

4.2.1. 취약점 개요 53

4.2.2. 권고사항 53

4.3. 디렉터리 리스팅 취약 54

4.3.1. 취약점 개요 54

4.3.2. 권고사항 54

4.4. 불필요 파일 존재 및 파일 다운로드 55

4.4.1. 취약점 개요 55

4.4.2. 권고사항 55

4.5.1. 페이지 내 관리자 페이지 링크 여부 56

4.5.1.1. 취약점 개요 56

4.5.1.2. 권고사항 56

4.5.2 관리자 페이지 접근 여부 56

4.5.2.1. 취약점 개요 56

4.5.2.2 권고사항 57

4.5.3 비인가 페이지 강제 호출 여부 57

4.5.3.1 취약점 개요 57

4.5.3.2. 권고사항 57

4.6.1 쿠키 재사용 (Replay Attack) 여부 58

4.6.1.1. 취약점 개요 58

Copyright ⓒ 2022 By ngnicky All Rights Reserved.

4.6.1.2. 권고사항 58

4.6.2 중요 페이지 세션/인증/접근 체크 여부 59

4.6.2.1. 취약점 개요 59

4.6.2.2. 권고사항 59

4.6.3클라이언트 인증 우회 여부 (Javascript 우회) 60

4.6.3.1. 취약점 개요 60

4.6.3.2. 권고사항 60

4.8.1 URL 정보 내 파라미터 위/변조 여부 62

4.8.1.1. 취약점 개요 62

4.8.1.2. 권고사항 62

4.8.2 필드 값 조작에 따른 검증 여부 63

4.8.2.1. 취약점 개요 63

4.8.2.2. 권고사항 63

4.9. XSS (XST / TRACE) 64

4.9.1. 취약점 개요 64

4.9.2. 권고사항 64

4.10.1 중요 개인정보 노출 여부 65

4.10.1.1 취약점 개요 65

4.10.1.2. 권고사항 65

4.10.2 쿠키 값 내 중요정보 유출 여부 65

4.10.2.1. 취약점 개요 65

4.10.2.2 권고사항 66

4.10.3 데이터베이스 관련 정보 유출 여부 66

4.10.3.1. 취약점 개요 66

4.10.3.2. 권고사항 67

4.10.4.1. 취약점 개요 67

4.10.4.2. 권고사항 67

Copyright ⓒ 2022 By ngnicky All Rights Reserved.

4.11. SQL Injection 68

4.11.1. 취약점 개요 68

4.11.2. 권고사항 68

4.12. 파일 업로드 취약점 69

4.12.1. 취약점 개요 69

4.12.2. 권고사항 70

Copyright ⓒ 2022 By ngnicky All Rights Reserved.

그림 목차

그림 1-1 모의해킹 수행 단계 12

그림 3-3 Server 헤더를 통한 버전 정보 노출 21

그림 3-4 Nmap을 이용한 버전 탐지 결과 22

그림 3-5 Nikto 점검 결과 — 구버전 경고 23

그림 3-6 노출된 버전에 대한 공개 취약점(Exploit) 검색 결과(1) 23

그림 3-7 노출된 버전에 대한 공개 취약점(Exploit) 검색 결과(2) 23

그림 3-8 /gm/lib 디렉터리 목록 노출 25

그림 3-9 디렉터리 목록 원본(raw) — 비추측성 파일까지 열거 26

그림 3-10 solution.sql 다운로드 — 회사 정보 노출 27

그림 3-11 solution.sql 내 admin 테이블 — 관리자 계정 평문 노출 28

그림 3-12 사이트 전체 백업 파일(gm.zip) 다운로드 29

그림 3-13 백업 파일 내 DB 접속 정보 평문 노출 30

그림 3-14 솔루션 구성도 문서 내 DB 스키마 및 개인정보 필드 노출 31

그림 3-15 burp suite를 사용한 관리자 페이지 여부 확인 32

그림 3-16 관리자 페이지 접근 여부와 강제 호출 여부 확인 32

그림 3-17 사용자 1차 로그인 시 sessionID 확인 결과 34

그림 3-18 로그아웃 후 2차 로그인 시 sessionID 확인 결과 35

그림 3-19 관리자 sessionID 확인 결과 35

그림 3-20 관리자 기능 접근 여부 확인 36

그림 3-21 자바 스크립트를 통해 투표 기능 활성화 37

그림 3-22 투표 성공 여부 확인 38

그림 3-23 관리자 페이지 로그인 시도 (admin/admin 입력) 39

그림 3-24 Burp Suite Request 패킷 — adminId=admin&adminPwd=admin 평문 전송 확인 40

그림 3-25 Burp Suite Response 패킷 — HTTP 200 OK 및 서버 버전 정보 노출 40

그림 3-26 관리자 페이지 접근 성공 — 전체 주문 정보 열람 가능 41

그림 3-27 b374k 웹쉘 DB 조회 — adminId, adminPwd 평문 저장 확인 41

그림 3-28 url내 idx값 변경 전 계정주인 확인 43

Copyright ⓒ 2022 By ngnicky All Rights Reserved.

그림 3-29 url내 idx값 변경 후 계정주인 확인 43

그림 3-30 상품구매 페이지의 필드 값 변경 44

그림 3-31 상품구매 결과 값 확인 45

그림 3-32 TRACE 요청 시 요청 헤더 및 세션 쿠키 반사 46

그림 3-33 와이어 샤크를 통한 패킷 확인 48

그림 3-34 페이지 내 '입력 결과 49

그림 3-35 SQL Injection 데이터 탈취 성공 50

그림 3-36 SQL Injection 로그인 시도 51

그림 3-38 PHP 파일 업로드 차단 53

그림 3-39 Burp Suite를 이용한 검증 로직 주석처리 54

그림 3-40 PHP 파일 업로드 성공 55

Copyright ⓒ 2022 By ngnicky All Rights Reserved.

표 목차

표 1-1 모의해킹 진단 일정 11

표 1-2 담당자별 수행 내역 11

표 1-3 모의해킹 수행 범위 12

표 1-4 모의해킹 장애 처리 12

표 1-5 수행 단계 설명 13

표 1-6 점검 항목 14

표 1-7 점검 도구 14

표 2-1 모의해킹 진단 내역 16

표 3-1 에러 메시지 처리 점검 항목 19

표 3-5 관리자 페이지 추측 및 URL 강제 호출 점검 항목 31

표 3-6 인증 우회 점검 항목 33

표 3-7 계정정보 추측 및 대입 점검 항목 39

표 3-8 파라미터 조작 점검 항목 42

표 3-10 페이지내 중요 정보 노출 점검 항목 47

표 3-11 SQL Injection 점검 항목 49

표 3-12 파일 업로드 점검 항목 51

표 4-1 에러 메시지 점검 방법 55

표 4-2 에러 메시지 정보 노출 보안 설정 방법 55

표 3-12 SQL Injection 테스트 입력값 예시 70

표 3-13 SQL Injection 보안 설정 방법 71

표 3-14 파일 업로드 취약점 점검 방법 72

표 3-15 파일 업로드 취약점 보안 설정 방법 73

Copyright ⓒ 2022 By ngnicky All Rights Reserved.

	시나리오 기반 GM Shop 모의해킹 결과 보고서		
	Category	문서 버전	문서 최종 수정일
	Development Report	1.1.4	2026.06.04

1. 개요

1.1. 모의해킹 정의

본 모의해킹 진단은 웹 서비스의 관련된 모든 정보 자산에 대해 취약점을 도출/분석 하여 대책을 수립하기 위한 것이다. 시나리오 기반으로 해커와 동일한 환경과 조건, 기술을 가지고 모의 침투를 실행하여 취약점을 발견하고, 발견된 취약점을 점검하여 사전 예방을 통한 보안 현황 확인과 대응 방안 확립을 목적으로 한다.

1.2. 수행일정/수행내역

본 모의해킹은 2026년 06월 02일부터 ~ 2026년 06월 04일까지 약 3일간 진행이 되며, 총 0.5M/M가 투입된다. Task 별 자세한 일정은 아래 표와 같다.

06월 02일(화)	06월 03일(수)	06월 04일(목)
환경분석 모의해킹 수행	모의해킹 수행 보고서 작성	보고서 작성 보고서 공유

표 1-1 모의해킹 진단 일정

담당자	수행 범위	E-Mail
팀원 B	취약점 진단 및 보고서 작성	-
백세희	취약점 진단 및 보고서 작성	sehee1236@gmail.com
팀원 C	취약점 진단 및 보고서 작성	-
팀원 E	취약점 진단 및 보고서 작성	-

표 1-2 담당자별 수행 내역

1.3. 수행 대상 및 장소

본 모의해킹은 아래 표 1-3의 GM Shop 웹 서비스를 대상으로 진단하며, Task별로 해당 대상에 대해 점검을 진행했다.

구분(Task)	대상 도메인	대상 IP 정보	서비스

Copyright ⓒ 2022 By ngnicky All Rights Reserved.

	시나리오 기반 GM Shop 모의해킹 결과 보고서		
	Category	문서 버전	문서 최종 수정일
	Development Report	1.1.4	2026.06.04

내부 모의해킹	<IP>/gm/	192.168.XXX.XXX	Apache / MySQL

표 1-3 모의해킹 수행 범위

본 모의해킹은 내부 IP대역에서 진행하였으며, 취약점 점검 수행자는 VMWare 내 Bee-box 환경에서 ipconfig를 통해 대상 IP를 확인한다. 점검 수행 시 장애가 발생하면 담당자에게 즉시 보고한다.

구분(Task)	수행자 IP	장소
내부 모의해킹	-	자택

표 1-4 모의해킹 장애 처리

1.4. 수행 단계별 방법

본 모의해킹은 단계별로 정보 수집부터 보고서 작성까지 아래 그림 1-1의 과정을 통해 진행된다.



그림 1-1 모의해킹 수행 단계

각 수행 단계별 요약 설명은 아래 표 1-5와 같다.

수행 단계	설명
정보 수집	대상에 대한 서버/네트워크/서비스에 대한 불필요한 서비스 접근 가능성, 외부에서 파악할 수 있는 정보들을 수집하는 단계
취약점 분석	각 네트워크 구간별로 적합한 취약점 스캔 도구를 이용하여 발생할 수 있는 취약점에 대한 정보를 수집하는 단계 (단, 네트워크 장비/서비스에 장애를 유발할 수 있는 경우에는 제외)
침투 테스트	취약점 정보 수집 및 분석 단계를 통해 획득한 정보를 기반으로 수동 점검하여 시스템 내부까지 침투할 수 있는지 시나리오 기반으로 접근하는 단계
실제 공격	취약점이 확인되었을 때 공격에 의한 시스템 보안 위협이 시스템 및 비지니스 측면에서 어느 정도의 영향을 미칠 수 있는지 분석하는 단계

Copyright ⓒ 2022 By ngnicky All Rights Reserved.

	시나리오 기반 GM Shop 모의해킹 결과 보고서		
	Category	문서 버전	문서 최종 수정일
	Development Report	1.1.4	2026.06.04

보고서 작성	도출된 취약점에 대한 총평/영향도/상세분석/보안가이드가 포함된 보고서를 작성하는 단계

표 1-5 수행 단계 설명

1.5. 점검 항목

점검 항목은 OWASP TOP 10, SANS TOP 25, KISA 48대 취약점 항목 등을 기반으로 제작된 자사의 취약점 점검 방법론을 이용하여 진행된다.

순번	분류	코드	점검 항목
1	계정정보 추측 및 대입	BP-001	취약한 패스워드 설정 여부
		BP-002	애플리케이션/장비 기본 패스워드 설정 여부
2	인증 우회	BP-003	쿠키 재사용 (Replay Attack) 여부
		BP-004	중요페이지 세션/인증/접근 체크 여부
		BP-005	클라이언트 인증 우회 여부 (Javascript 우회)
3	파라미터 조작	BP-006	URL 정보 내 파라미터 위/변조 여부
		BP-007	필드 값 조작에 따른 검증 여부
4	XSS (CSRF) 취약점	BP-008	악의적인 스크립트 필터링 여부 (POST 메소드)
		BP-009	URL 파라미터 필터링 여부 (GET 메소드)
		BP-010	XST, TRACE 옵션 허용 여부
		BP-011	CSRF 취약점 허용 여부
5	에러 메시지 처리	BP-012	에러 메시지를 통한 중요/불필요한 정보 유출
6	디렉터리 리스팅 취약점	BP-013	디렉터리 리스팅 여부
7	관리자 페이지 추측	BP-014	페이지 내 관리자 페이지 링크 여부
		BP-015	관리자 페이지 접근 여부
8	페이지내 중요 정보 노출	BP-016	중요 개인정보 노출 여부
		BP-017	쿠키 값 내 중요정보 유출 여부
		BP-018	데이터베이스 관련 정보 유출 여부
		BP-019	중요정보 평문전송
9	불필요 파일 존재	BP-020	불필요한 페이지 존재 여부
		BP-021	백업, 압축 등 불필요 파일 존재 여부
		BP-022	테스트 페이지, 데모 페이지 삭제 여부
10	파일 다운로드 취약점	BP-023	입력 값 검증 미흡으로 파일 다운로드 공격 여부

Copyright ⓒ 2022 By ngnicky All Rights Reserved.

11	파일 업로드 취약점	BP-024	입력 값 검증 미흡으로 파일 업로드 공격 여부
12	부적절한 Include 취약점	BP-025	부적절한 Include 허용 여부
13	URL 강제 호출	BP-026	비인가 페이지 강제 호출 여부
14	SQL Injection	BP-027	SQL Injection 허용 여부
15	최신 취약점 미패치	BP-028	보안에 취약한 오래된 애플리케이션 사용 여부
16	부적절한 서버 설정	BP-029	서버 보안 설정 여부
17	법적 요구사항 검토	BP-030	개인정보보호법에 의한 적절성 여부

표 1-6 점검 항목

1.6. 점검 도구

본 모의해킹을 수행하면서 사용된 도구는 아래 표와 같다.

	용도	사이트
Nmap	취약점 분석	http://nmap.org/
DirBuster	디렉터리 스캔	http://sourceforge.net/projects/dirbuster/
Nikto	취약점 분석	https://cirt.net/Nikto2
BeEF	침투 테스트	http://BeEFproject.com/
Wireshark	네트워크 패킷 분석	https://www.wireshark.org/
SQLMap	SQL Injection 테스트	www.sqlmap.org/
BurpSuite	프록시	http://portswigger.net/Burp/
Metasploit	침투 테스트	www.metasploit.com

표 1-7 점검 도구

Copyright ⓒ 2022 By ngnicky All Rights Reserved.

2. 결과 요약

2.1. 총평

본 모의해킹 진단은 내부 서비스를 대상으로 이루어졌다. 그 결과 총 43개의 취약점이 발견되었다. 주요 취약점은 아래 표 2-1와 같다.

취약점	요약
계정정보 추측 및 대입	단순한 패스워드 설정으로 계정정보 추측 가능
인증 우회	GM Shop 웹 서비스는 세션 토큰을 장기간 유지하는 구조로 확인. BeEF 기반 XSS 공격을 통해 관리자 세션 토큰이 탈취될 경우, 공격자 PC에서 별도의 인증 절차 없이 관리자 계정으로 로그인 가능
파라미터 조작	페이지 파라미터 변조로 다른 사용자의 정보나 다른 페이지의 정보에 접근 가능
XSS 취약점	게시판 서비스에 악성 스크립트 삽입 및 다른 사용자 권한 획득이 가능하며, 바이러스 배포 가능
에러 메시지 처리	검색 기능 입력값에 SQL 구문 오류를 유발하는 문자 삽입 시, PHP 오류 메시지 및 서버 내부 경로 노출
디렉터리 리스팅	디렉토리 리스팅 가능 여부 확인
관리자 페이지 추측	메인 페이지 내 관리자 로그인 페이지 링크 여부 확인
페이지내 중요 정보 노출	노출된 데이터베이스 덤프 내에 관리자 정보 등의 주요 정보 노출
불필요한 파일 존재	서비스 개발 이후에 불필요한 백업 파일 존재로 소스 파일 일부 노출
파일 다운로드	불필요한 백업 파일 및 중요 파일이 인증 없이 다운로드 가능
파일 업로드	파일 업로드 기능에 확장자 검증 우회가 가능하며, 비인가 파일 업로드 가능
부적절한 Include 취약점	외부 및 내부 파일 Include를 통한 비인가 파일 호출 가능
URL 강제 호출	Url에 /admin을 통해 직접적으로 관리자 페이지 호출 가능
SQL Injection	사용자 입력 기능에 SQL 구문 삽입 시, 비정상 동작 발생
최신 취약점 미패치	Server 헤더를 통해 구버전 웹 서비스 구성 정보 확인
부적절한 서버 설정	TRACE 메서드 및 디렉터리 리스팅 활성화 확인
법적 요구사항 검토	개인정보 보호 및 정보통신망 보안 요구사항과 관련된 접근통제, 인증, 암호화 설정 미흡 사항 확인

Copyright ⓒ 2022 By ngnicky All Rights Reserved.

	시나리오 기반 GM Shop 모의해킹 결과 보고서		
	Category	문서 버전	문서 최종 수정일
	Development Report	1.1.4	2026.06.04

표 2-1 모의해킹 진단 내역

2.2. 취약점 요약

[에러 메시지 처리 미흡]

비정상적인 입력값에 대한 예외처리가 미흡하여 데이터베이스 오류 메시지 및 서버 내부 정보가 사용자 화면에 그대로 노출되는 경우이다. 공격자는 노출된 오류 메시지를 통해 서버 내부 경로, 데이터베이스 종류 및 구조, 사용 중인 소프트웨어 버전 등의 정보를 획득할 수 있으며 이를 기반으로 SQL Injection 등의 추가적인 공격을 수행할 수 있다.

[최신 취약점 미패치]

웹 서버 및 구성 소프트웨어가 지원 종료(EOL)된 구버전을 사용하고 있으며 최신 보안 패치가 적용되지 않은 상태이다. 공격자는 공개된 취약점 정보(CVE)와 익스플로잇 코드를 활용하여 원격 코드 실행, 정보 유출, 서비스 장애 등의 공격을 수행할 수 있으며 시스템 전체가 침해될 위험이 존재한다.

[디렉터리 리스팅 취약점]

웹 서버의 디렉터리 인덱싱 기능이 활성화되어 디렉터리 내 파일 목록이 외부에 노출되는 경우이다. 공격자는 노출된 파일 목록을 통해 소스코드, 설정 파일, 백업 파일 등의 존재 여부를 파악할 수 있으며, 이를 기반으로 민감 정보 유출 및 추가 공격을 수행할 수 있다.

[불필요한 파일 다운로드]

서비스 운영에 불필요한 백업 파일, 데이터베이스 스크립트, 테스트 페이지 등이 웹 경로에 그대로 노출되어 인증 없이 다운로드 가능한 경우이다. 공격자는 해당 파일을 통해 소스코드, 데이터베이스 접속 정보, 관리자 계정 정보 등 민감한 정보를 획득할 수 있으며 이를 통해 시스템 장악 및 추가 침해사고로 이어질 수 있다.

[관리자 페이지 추측 URL 강제 호출]

관리자 페이지 경로가 쉽게 추측 가능하거나 접근 제어가 미흡하여 비인가 사용자가 URL 직접 입력만으로 관리자 페이지에 접근 가능한 경우다. 공격자는 인증 절차 없이 관리자 페이지에 접근할 수 있다.

[인증 우회]

세션 관리 및 인증 검증 로직이 미흡하여 공격자가 탈취한 세션 쿠키를 재사용하거나 인증 절차를 우회할 수 있는 경우이다. 공격자는 정상 사용자 또는 관리자 권한을 획득하여 개인정보 조회, 관리자 기능 수행

Copyright ⓒ 2022 By ngnicky All Rights Reserved.

등 권한이 필요한 기능을 불법적으로 수행할 수 있다.

[계정 정보 추측 및 대입]

관리자 계정에 기본 패스워드 또는 추측 가능한 단순 문자열이 설정되어 있으며 패스워드가 데이터베이스 내에 평문으로 저장되어 있는 경우이다. 공격자는 기본 계정 정보만으로 관리자 페이지에 접근할 수 있으며 이를통해 회원 개인정보 열람, 주문 정보 조회 및 시스템 설정 변경 등 관리자 권한을 악용할 수 있다. 또한 데이터베이스가 유출될 경우 저장된 계정 정보가 즉시 노출되어 추가적인 계정 탈취 및 시스템 침해로 이어질 수 있다.

[매개변수 변조 취약점]

URL 파라미터 및 요청 데이터에 대한 서버 측 검증이 미흡하여 사용자가 전달하는 값을 임의로 변경할 수 있는 경우이다. 공격자는 다른 사용자의 게시글 조회, 결제 금액 변경, 권한 상승 등의 행위를 수행할 수 있으며 이를 통해 개인정보 유출 및 금전적 피해가 발생할 수 있다.

[XSS (XST/Trace)]

웹 서버에서 HTTP TRACE 메서드가 활성화되어 있어 요청 헤더 및 세션 쿠키 정보가 응답 본문에 그대로 반사되는 경우이다. 공격자는 XST(Cross-Site Tracing) 공격을 통해 사용자의 세션 쿠키 및 인증 정보를 탈취할 수 있다. 탈취한 세션 정보를 이용하여 사용자 계정 도용 미 인증 우회 공격이 가능하다.

[페이지 내 중요 정보 노출]

웹 페이지 및 네트워크 통신 과정에서 개인정보, 세션 정보, 데이터베이스 관련 정보 등이 평문으로 노출되는 경우이다. 공격자는 패킷 스니핑, 쿠키 탈취, 에러 메시지 분석 등을 통해 중요 정보를 획득할 수 있으며 이를 이용한 계정 탈취 및 추가 공격이 가능하다.

[SQL Injection]

사용자 입력값에 대한 검증이 미흡하여 SQL 질의문이 비정상적으로 조작될 수 있는 경우이다. 공격자는 SQL Injection 공격을 통해 인증 우회, 데이터베이스 정보 조회 및 수정, 관리자 계정 탈취 등 심각한 공격을 수행할 수 있다. 최악의 경우 서버 장악으로 이어질 수 있다.

[파일 업로드 취약점]

파일 업로드 기능에서 확장자 및 파일 유형 검증이 미흡하거나 클라이언트 측 검증에만 의존하는 경우이다. 공격자는 검증 로직을 우회하여 악성 스크립트 파일을 업로드 할 수 있으며 이를 통해 웹쉘 실행, 서버 명령 수행 및 시스템 장악 등의 공격이 가능하다.

Copyright ⓒ 2022 By ngnicky All Rights Reserved.

3. 상세 수행 내역

3.1. 에러 메시지 처리

분류	코드	점검 항목
에러 메시지 처리	BP-012	에러 메시지를 통한 중요/불필요한 정보 유출

표 3-1 에러 메시지 처리 점검 항목

3.1.1. 체크리스트 검증

▫ 데이터베이스 에러 메시지 노출 여부

웹 애플리케이션에서 입력값 처리 중 예외 상황이 발생하였을 때 상세한 오류 메시지가 사용자 화면에 그대로 출력될 경우 발생하는 취약점이다. 노출된 오류 메시지에는 서버 내부 경로, 데이터베이스 쿼리 구조, 파일명, 라인 번호 등의 정보가 포함될 수 있으며 공격자는 이를 추가 공격에 활용할 수 있다.

상품 검색 기능을 처리하는 search_result.php 페이지에 특수문자(')를 포함한 비정상적인 입력값을 전달하여 에러 메시지 노출 여부를 점검하였다.

Copyright ⓒ 2022 By ngnicky All Rights Reserved.



그림 3-1 브라우저 화면에 출력된 에러 메시지 — 서버 내부 경로 노출

위 그림 3-1과 같이 검색창에 특수문자(')를 입력하였을 때 Warning: mysql_num_rows() 오류 메시지가 화면에 그대로 출력되는 것을 확인하였다. 노출된 메시지를 통해 MySQL 사용 여부, 서버 내부 파일 경로(/var/www/gm/search_result.php), 오류 발생 라인 번호(line 116) 등 민감한 정보를 파악할 수 있었다.



그림 3-2 Burp Suite Response 패킷 — Server 헤더에 서버 버전 정보 노출

위 그림 3-2는 Burp Suite를 통해 확인한 서버의 응답 패킷이다. 응답 헤더의 Server 항목에 Apache/2.2.8 (Ubuntu), PHP/5.2.4, OpenSSL/0.9.8g 등 현재 운영 중인 서버의 상세 버전 정보가 노출되고 있음을 확인하였다. 이는 공격자가 해당 버전에 알려진 취약점을 검색하여 추가 공격에 활용할 수 있으므로 반드시 제거하여야 한다.

Copyright ⓒ 2022 By ngnicky All Rights Reserved.

3.2. 최신 취약점 미패치

분류	코드	점검 항목
최신 취약점 미패치	BP-028	보안에 취약한 오래된 어플리케이션 사용 여부

표 3-2 최신 취약점 미패치 점검 항목

3.2.1. 체크리스트 검증

▫ **보안에 취약한 오래된 어플리케이션 사용 여부**

웹 서버가 응답하는 HTTP 헤더에 구성 소프트웨어의 상세 버전 정보가 그대로 노출될 경우, 공격자는 해당 버전에 대해 공개된 알려진 취약점(CVE)을 손쉽게 검색하여 공격에 활용할 수 있다. 본 점검에서는 응답 헤더 및 버전 탐지 도구를 통해 대상 서버의 구성 소프트웨어 버전과 패치 적용 여부를 확인하였다.

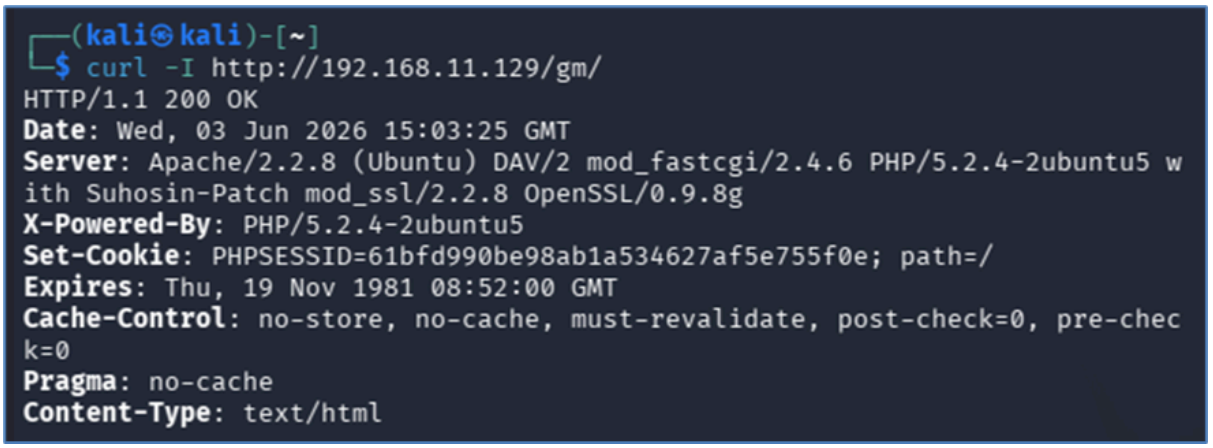


그림 3-3 Server 헤더를 통한 버전 정보 노출

위 그림과 같이 curl -I 요청에 대한 응답 헤더에서 대상 서버는 Apache/2.2.8, PHP/5.2.4-2ubuntu5, OpenSSL/0.9.8g의 버전 정보를 그대로 노출하고 있으며, 별도의 X-Powered-By: PHP/5.2.4-2ubuntu5 헤더를 통해 PHP 버전이 한 번 더 노출되고 있다. 해당 버전들은 모두 2007~2008년에 배포된 구버전으로 현재 지원이 종료(EOL)된 상태이며, 보안 패치가 적용되지 않은 것으로 확인된다.

Copyright ⓒ 2022 By ngnicky All Rights Reserved.

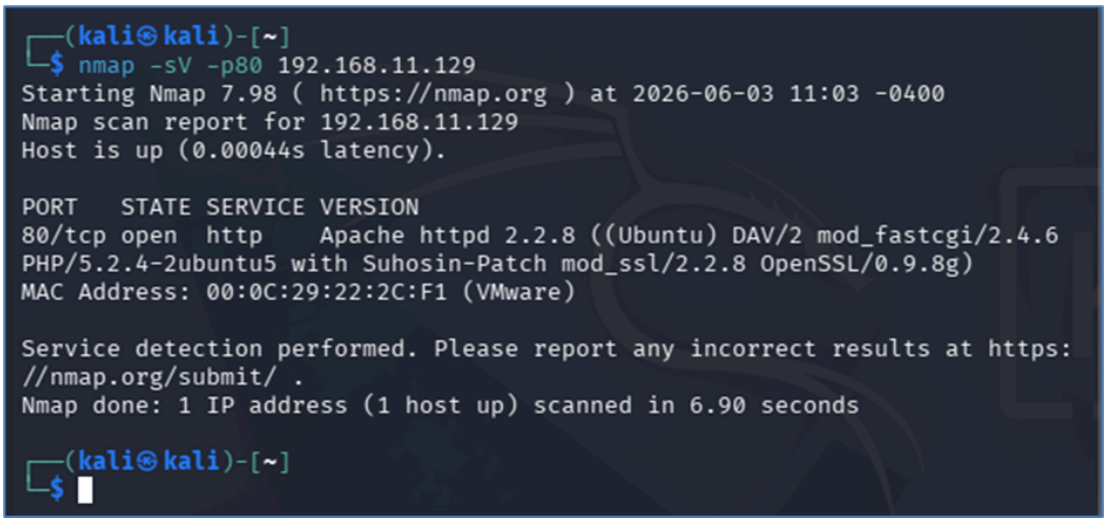
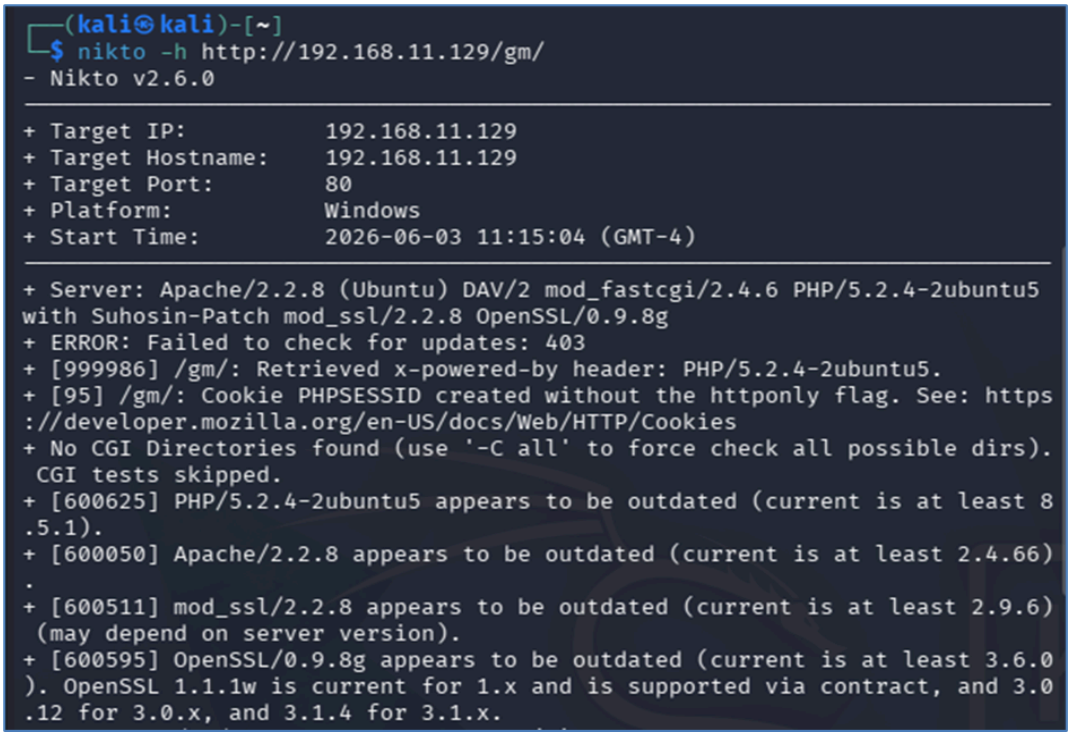


그림 3-4 Nmap을 이용한 버전 탐지 결과

응답 헤더 외에 Nmap 버전 탐지(nmap -sV)를 통해서도 동일하게 Apache httpd 2.2.8, OpenSSL/0.9.8g 등의 버전이 식별되어, 외부에서 구성 정보를 명확히 파악할 수 있음을 교차 확인하였다.



Copyright ⓒ 2022 By ngnicky All Rights Reserved.

그림 3-5 Nikto 점검 결과 — 구버전 경고

웹 취약점 스캐너 Nikto로 점검한 결과, Apache·PHP·mod_ssl·OpenSSL이 모두 구버전("appears to be outdated")이라는 경고가 다수 출력되었으며, HttpOnly 플래그 미설정 등 부가적인 설정 미흡도 함께 확인되었다.

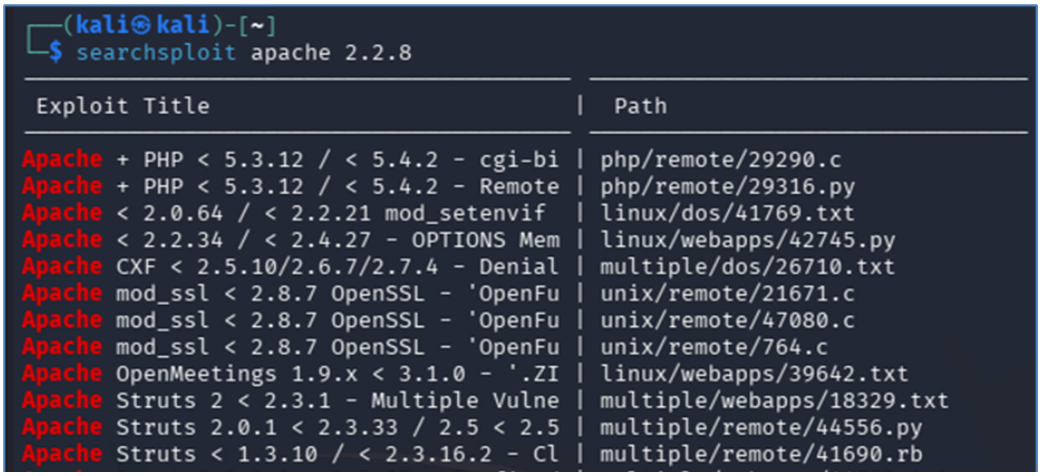


그림 3-6 노출된 버전에 대한 공개 취약점(Exploit) 검색 결과(1)



그림 3-7 노출된 버전에 대한 공개 취약점(Exploit) 검색 결과(2)

Copyright ⓒ 2022 By ngnicky All Rights Reserved.

searchsploit를 통해 확인한 결과, 노출된 Apache 2.2.8 및 OpenSSL 0.9.8 버전에 대해 원격 코드 실행, 정보 노출 등 다수의 공개된 익스플로잇이 존재함을 확인하였다. 이는 해당 구버전이 실제 공격에 악용될 수 있는 위험에 노출되어 있음을 의미한다.

3.3. 디렉터리 리스팅

분류	코드	점검 항목
디렉터리 리스팅 취약점	BP-013	디렉터리 리스팅 여부

표 3-3 디렉터리 리스팅 점검 항목

3.3.1. 체크리스트 검증

▫ 디렉터리 리스팅 여부

웹 서버에 디렉터리 인덱싱(Options Indexes) 기능이 활성화되어 있고 해당 디렉터리에 기본 문서(index.html, index.php 등)가 존재하지 않을 경우, 해당 경로로 접근하면 디렉터리 내 파일 목록이 그대로 노출된다. 이를 통해 공격자는 소스 파일, 설정 파일, 백업 파일 등의 존재와 경로를 열거(enumeration) 하여 후속 공격의 단서를 확보할 수 있다.

Copyright ⓒ 2022 By ngnicky All Rights Reserved.

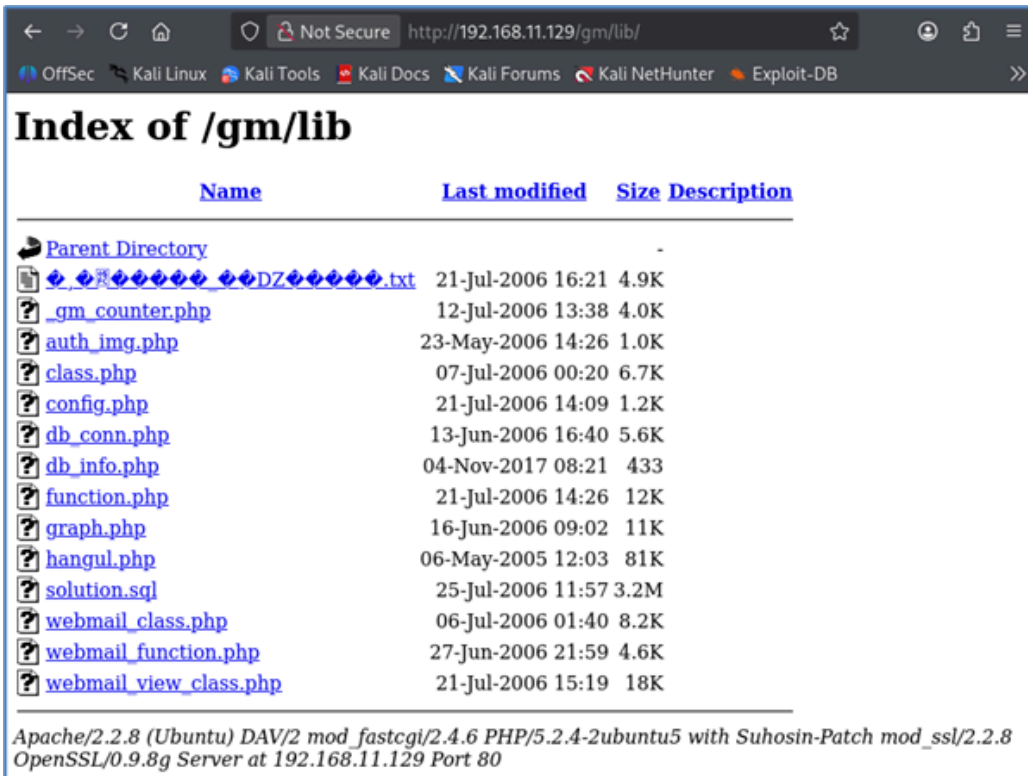


그림 3-8 /gm/lib 디렉터리 목록 노출

위 그림과 같이 http://대상/gm/lib/ 경로로 접근하면 "Index of /gm/lib" 형태로 디렉터리 내 파일 목록이 그대로 노출된다. 목록에는 config.php, db_conn.php, db_info.php 등 데이터베이스 설정 관련 소스 파일과 solution.sql, 솔루션 구성도 문서(.txt) 등이 포함되어 있어, 공격자에게 내부 소스·설정 파일 및 민감 파일의 이름과 위치 정보가 그대로 제공된다.

Copyright ⓒ 2022 By ngnicky All Rights Reserved.

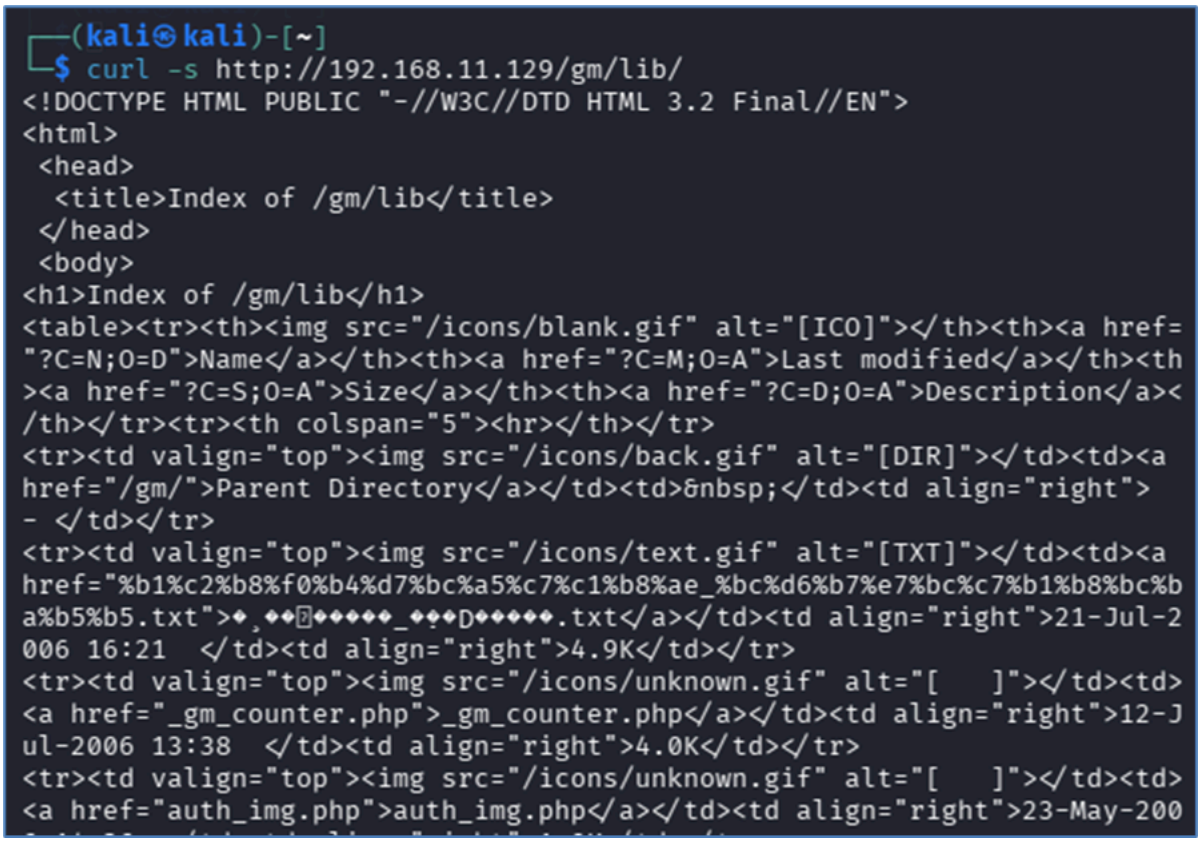


그림 3-9 디렉터리 목록 원본(raw) — 비추측성 파일까지 열거

curl 로 동일 경로를 요청한 원본 응답을 보면, 무차별 대입(brute-force)으로는 식별하기 어려운 한글 파일명의 문서까지 목록(href)을 통해 그대로 노출되는 것을 확인하였다. 즉 디렉터리 리스팅으로 인해 파일명 추측이 불가능한 자료까지 열거가 가능하다.

※ 본 절은 "파일 목록이 노출되어 열거 가능" 한 사실까지만 다루며, 노출된 개별 파일의 다운로드 및 내용 유출은 「3.4 불필요 파일 존재 및 파일 다운로드」에서 상세히 기술한다.

3.4. 불필요한 파일 다운로드

분류	코드	점검 항목

Copyright ⓒ 2022 By ngnicky All Rights Reserved.

불필요 파일 존재	BP-020	불필요한 페이지 존재 여부
	BP-021	백업, 압축 등 불필요 파일 존재 여부
	BP-022	테스트 페이지, 데모 페이지 삭제 여부
파일 다운로드	BP-023	입력 값 검증 미흡으로 인한 파일 다운로드 공격

표 3-4 불필요 파일 존재 및 파일 다운로드 점검 항목

3.4.1. 체크리스트 검증

□ 백업·불필요 파일 존재 및 직접 다운로드

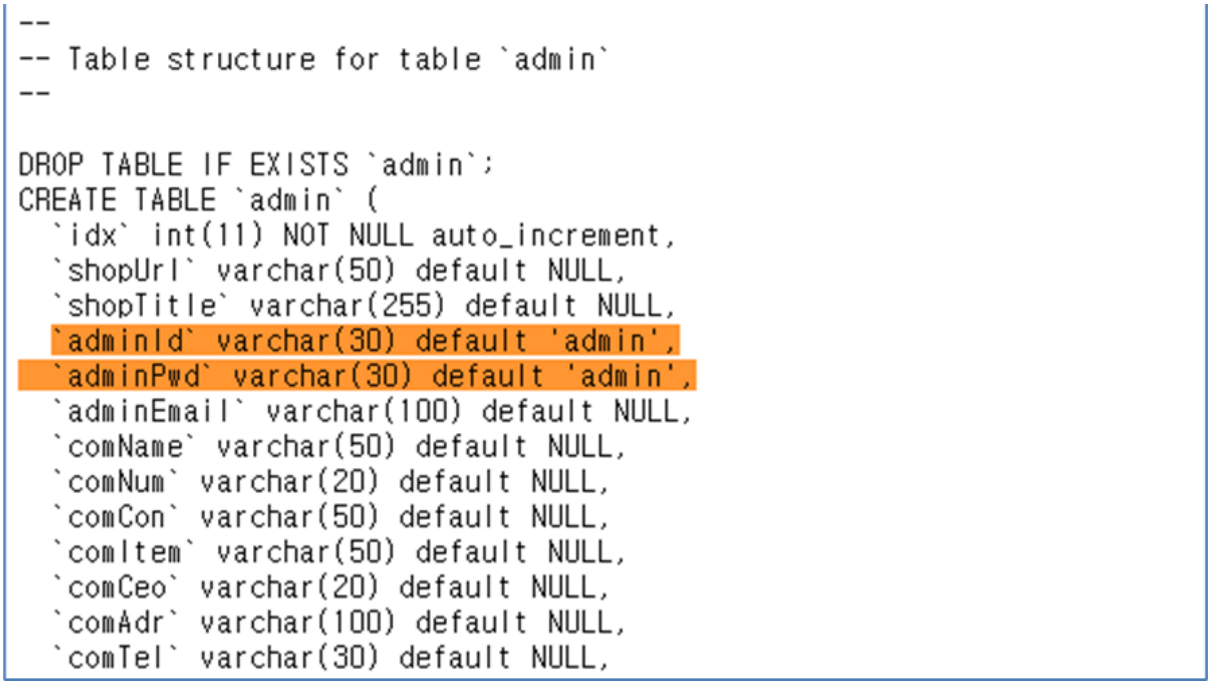
서비스 운영에 불필요한 데이터베이스 스크립트, 사이트 백업 파일, 설계 문서, 테스트 페이지 등이 웹 루트에 방치되고 접근 제한이 없을 경우, 인증 없이 누구나 해당 파일을 직접 다운로드할 수 있으며 그 내부의 민감 정보(소스코드, DB 접속 정보, 개인정보 등)가 그대로 유출된다. 본 점검에서는 직접 다운로드 가능한 다수의 불필요 파일과 그로 인한 민감 정보 유출을 확인하였다.



그림 3-10 solution.sql 다운로드 — 회사 정보 노출

http://대상/gm/lib/solution.sql 경로로 접근하면 별도의 인증 없이 누구나 해당 데이터베이스 스크립트(약 3.2MB)를 다운로드할 수 있다. 파일 내부에는 대표자명, 사업자등록번호, 소재지, 대표전화 등 사업자 정보가 평문으로 포함되어 있다.

Copyright ⓒ 2022 By ngnicky All Rights Reserved.



```
--
-- Table structure for table `admin`
--

DROP TABLE IF EXISTS `admin`;
CREATE TABLE `admin` (
  `idx` int(11) NOT NULL auto_increment,
  `shopUrl` varchar(50) default NULL,
  `shopTitle` varchar(255) default NULL,
  `adminId` varchar(30) default 'admin',
  `adminPwd` varchar(30) default 'admin',
  `adminEmail` varchar(100) default NULL,
  `comName` varchar(50) default NULL,
  `comNum` varchar(20) default NULL,
  `comCon` varchar(50) default NULL,
  `comItem` varchar(50) default NULL,
  `comCeo` varchar(20) default NULL,
  `comAdr` varchar(100) default NULL,
  `comTel` varchar(30) default NULL,
```

그림 3-11 solution.sql 내 admin 테이블 — 관리자 계정 평문 노출

또한 동일 파일의 admin 테이블 정의를 보면 관리자 계정(adminId 기본값 admin)과 비밀번호(adminPwd)가 varchar(30) 형태로, 즉 **암호화(해시) 없이 평문으로** 저장되어 있어 관리자 계정 정보가 그대로 노출된다.

Copyright ⓒ 2022 By ngnicky All Rights Reserved.

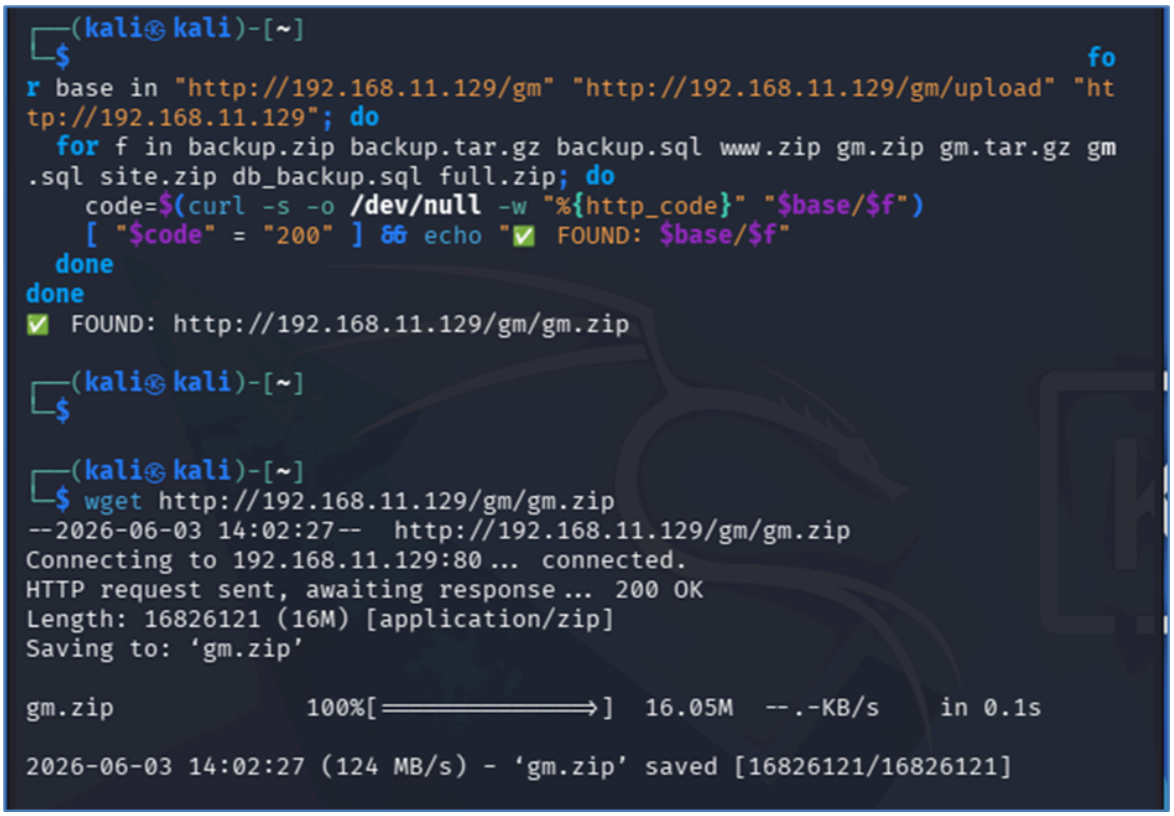


그림 3-12 사이트 전체 백업 파일(gm.zip) 다운로드

사이트명 기반 추측을 통해 웹 루트에서 전체 백업 파일 gm.zip(약 16MB)을 확인하였으며, 인증 없이 누구나 다운로드할 수 있다. 해당 백업에는 서비스 전체 PHP 소스코드가 포함되어 있다.

Copyright ⓒ 2022 By ngnicky All Rights Reserved.

```
┌──(kali㉿kali)-[~]
└─$ iconv -f euc-kr -t utf-8 gm_backup/lib/db_info.php
<?
////////////////////////////////////////////////////////////////
// 프로그램명    : db_info.php
// 설명          : 데이타베이스의 정보
// 작성자        : 최호수
// 소 속         : (주)올플랜
// 일 자         : 2006년 7월 3일 월요일
////////////////////////////////////////////////////////////////
/*
프로그램 설명
2006-07-03 : 굿모닝샵 베스트(가칭) 제작
*/

$arrDBINFO=array("localhost","3306","gmshop","root","bug"); // 호스트,포트
,DB명,DB아이디,DB패스워드
?>
```

그림 3-13 백업 파일 내 DB 접속 정보 평문 노출

다운로드한 백업의 데이터베이스 접속 정보 파일(lib/db_info.php)을 확인한 결과, MySQL 데이터베이스 계정 정보(아이디·비밀번호)가 평문으로 기재되어 있다. 웹에서 해당 PHP 파일을 직접 요청하면 서버에서 실행되어 소스가 노출되지 않으나, 백업 파일을 통해 우회적으로 소스 및 DB 접속 정보를 그대로 획득할 수 있어 위험도가 매우 높다. 또한 백업 내에는 전자지불(PG) 연동 인증서 및 개인키(AllplanPG/inicis/.../mpriv.pem 등)까지 포함되어 있어 결제 모듈 위·변조 위험도 존재한다.

```
~/[redacted].txt - Mousepad
File  Edit  Search  View  Document  Help
109
110 >>>>>member (회원)테이블 주요필드
111 name 이름
112 userid 아이디
113 pwd 비밀번호
114 email 이메일
115 ssh 주민등록번호
116 zip 우편번호
117 address1 주소
118 address2 상세주소
119 city 도시 (서울,대구..)
120 tel 전화번호
121 hand 핸드폰번호
122 bMail 메일수신여부 1,0
123 point 적립금
```


Copyright ⓒ 2022 By ngnicky All Rights Reserved.

그림 3-14 솔루션 구성도 문서 내 DB 스키마 및 개인정보 필드 노출

웹 루트에 방치된 솔루션 구성도 문서(.txt) 역시 평문으로 다운로드 가능하며, 전체 폴더 구조, 주요 소스 파일의 역할, 데이터베이스의 모든 테이블 구성, member 테이블의 필드 정보(비밀번호, 주민등록번호, 이메일, 주소, 연락처 등)가 상세히 기재되어 있다. 이는 공격자에게 시스템 내부 구조를 그대로 제공할 뿐 아니라, SQL Injection 등 후속 공격 시 대상 테이블·컬럼을 특정하는 데 직접 악용될 수 있다. 더불어 phpinfo.php 테스트 페이지(BP-022)도 삭제되지 않고 방치되어 PHP 설정·경로 등 서버 정보가 노출되는 것을 확인하였다.

3.5. 관리자 페이지 추측 및 URL 강제 호출

분류	코드	점검 항목
관리자 페이지 추측	BP-014	페이지 내 관리자 페이지 링크 여부
	BP-015	관리자 페이지 접근 여부
URL 강제 호출	BP-026	비인가 페이지 강제 호출 여부

표 3-5 관리자 페이지 추측 및 URL 강제 호출 점검 항목

3.5.1. 체크리스트 검증

페이지 내 관리자 페이지 링크 여부

웹 페이지의 소스코드, 주석, 숨겨진 링크 등에 관리자 페이지 경로가 노출되어 있을 경우 발생할 수 있는 취약점이다. 공격자가 페이지 소스를 분석하여 관리자 페이지 URL을 획득할 수 있으며, 이를 통해 관리자 페이지에 직접 접근을 시도하거나 추가적인 공격의 발판으로 활용될 수 있다.



Copyright ⓒ 2022 By ngnicky All Rights Reserved.

그림 3-15 burp suite를 사용한 관리자 페이지 여부 확인

그림 3-15와 같이 burp suite의 target 기능을 통해서 gmshop의 패킷을 확인해봤을 때, admin이라는 이름의 관리자 페이지가 존재한다는 것을 쉽게 확인할 수 있으며, 이러한 정보를 기반으로 공격자는 관리자 페이지에 접근 시도를 할 수 있다.

관리자 페이지 접근 여부

인증 및 접근 제어가 미흡하게 구현되어 일반 사용자 또는 비인가 사용자가 관리자 페이지에 접근 가능할 경우 발생할 수 있는 취약점이다. 공격자가 관리자 기능에 무단으로 접근하여 회원 정보 열람·수정·삭제, 시스템 설정 변경 등 권한을 남용할 수 있으며, 이는 대규모 개인정보 유출 및 서비스 전체의 침해사고로 이어질 수 있다.

비인가 페이지 강제 호출 여부

인증되지 않은 사용자가 URL을 직접 입력하거나 조작하여 접근이 제한된 페이지를 강제로 호출할 수 있을 경우 발생할 수 있는 취약점이다. 서버 측에서 인증 및 권한 검증이 적절히 이루어지지 않을 경우, 공격자가 로그인 절차를 우회하여 개인정보 조회 페이지, 결제 처리 페이지 등 민감한 기능에 접근할 수 있으며, 이를 통한 정보 유출 및 불법적인 기능 실행이 가능해진다.



그림 3-16 관리자 페이지 접근 여부와 강제 호출 여부 확인

그림 3-15와 같은 루트로 admin 페이지가 존재한다는 것을 알아냈을 때 그림 3-16과같이 공격자는 url에

Copyright ⓒ 2022 By ngnicky All Rights Reserved.

/admin 검색을 시도해 볼 수 있다. 이러한 방식으로 admin을 검색해본 결과 그림 3-16과 같이 관리자 페이지에 별도의 인증 없이 접근할 수 있는 것을 확인할 수 있다.

3.6. 인증 우회

분류	코드	점검 항목
인증 우회	BP-003	쿠키 재사용 (Replay Attack) 여부
	BP-004	중요페이지 세션/인증/접근 체크 여부
	BP-005	클라이언트 인증 우회 여부 (Javascript 우회)

표 3-6 인증 우회 점검 항목

3.6.1. 체크리스트 검증

쿠키 재사용 (Replay Attack) 여부

로그아웃 이후 또는 세션 만료 후에도 이전에 발급된 쿠키 값이 무효화되지 않고 재사용 가능하도록 웹 로직이 구현되어 있을 경우 발생할 수 있는 취약점이다. 공격자가 네트워크 스니핑이나 XSS 등을 통해 탈취한 쿠키를 재사용하면 정상적인 인증 절차 없이 피해자의 계정으로 세션을 재연결할 수 있으며, 이를 통해 개인정보 유출 및 계정 탈취 등의 침해사고가 발생할 수 있다.

Copyright ⓒ 2022 By ngnicky All Rights Reserved.

Request

Pretty Raw Hex

```
6 Origin: http://192.168.254.129
7 Content-Type: application/x-www-form-urlencoded
8 Upgrade-Insecure-Requests: 1
9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKi
  Safari/537.36
0 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,image/avif
  ange;v=b3;q=0.7
1 Referer: http://192.168.254.129/gm/index.php
2 Accept-Encoding: gzip, deflate, br
3 Cookie: POLL_COOKIE_11=yes; BEEFHOOK=pXWZw0xUq0I9ZRYHFuw04Cyk5Qq
  PHPSESSID=29635496ef5b6d129392c9701a2baf92; security_level=0
4 Connection: keep-alive
```

그림 3-17 사용자 1차 로그인 시 sessionID 확인 결과

Request

Pretty Raw Hex

```
6 Origin: http://192.168.254.129
7 Content-Type: application/x-www-form-urlencoded
8 Upgrade-Insecure-Requests: 1
9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKi
  Safari/537.36
0 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,image/avif
  ange;v=b3;q=0.7
1 Referer: http://192.168.254.129/gm/index.php
2 Accept-Encoding: gzip, deflate, br
3 Cookie: POLL_COOKIE_11=yes; BEEFHOOK=pXWZw0xUq0I9ZRYHFuw04Cyk5Qq
  PHPSESSID=29635496ef5b6d129392c9701a2baf92; security_level=0
4 Connection: keep-alive
```


Copyright ⓒ 2022 By ngnicky All Rights Reserved.

그림 3-18 로그아웃 후 2차 로그인 시 sessionID 확인 결과

세션 ID의 경우 사용자가 로그아웃을 한 경우 저장되어있던 세션 ID는 제거하고 다시 로그인 시 새로운 세션 ID를 발급해야한다. 하지만 현재 gmshop에서는 이러한 과정이 진행되지 않아 세션 ID가 같은 것을 확인할 수 있었고 이를 이용해 세션 ID를 탈취할 경우 로그아웃을 하더라도 해당 ID로 사이트에 접근할 수 있게 된다.

중요페이지 세션/인증/접근 체크 여부

마이페이지, 결제 페이지, 개인정보 변경 페이지 등 중요한 기능을 수행하는 페이지에서 세션 유효성 및 인증 여부를 적절히 검증하지 않을 경우 발생할 수 있는 취약점이다. 서버 측에서 매 요청마다 세션 및 인증 상태를 확인하지 않을 경우, 공격자가 인증 절차를 우회하여 중요 페이지에 접근할 수 있으며, 개인정보 열람 및 무단 거래 등 심각한 피해로 이어질 수 있다.

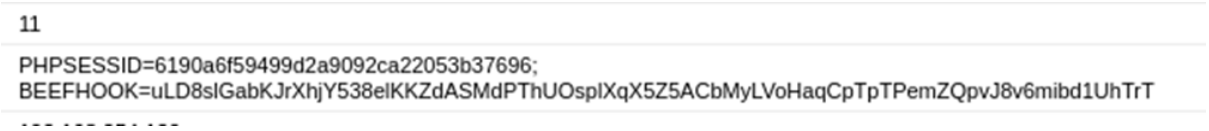


그림 3-19 관리자 sessionID 확인 결과

Copyright ⓒ 2022 By ngnicky All Rights Reserved.



그림 3-20 관리자 기능 접근 여부 확인

그림 3-19와 같이 공격자가 XSS와 BeEF를 활용하여 관리자이 세션ID를 탈취할 경우 공격자는 그림 3-20과 같이 관리자와 글 작성자만 확인할 수 있는 1:1 문의 게시판에도 접근하는 등의 관리자 권한을 이용할 수 있는 것을 확인할 수 있다.

클라이언트 인증 우회 여부 (Javascript 우회)

입력값 검증, 접근 제어, 인증 로직 등이 서버가 아닌 클라이언트 측 JavaScript에만 구현되어 있을 경우 발생할 수 있는 취약점이다. 공격자가 브라우저 개발자 도구나 프록시 툴을 이용하여 JavaScript 코드를 비활성화하거나 요청 값을 직접 조작함으로써 클라이언트 측 검증 로직을 손쉽게 우회할 수 있으며, 이를 통해 비정상적인 데이터 입력 및 인증 절차 없이 제한된 기능에 접근하는 침해사고가 발생할 수 있다.

Copyright ⓒ 2022 By ngnicky All Rights Reserved.



그림 3-21 자바 스크립트를 통해 투표 기능 활성화

Copyright ⓒ 2022 By ngnicky All Rights Reserved.



그림 3-22 투표 성공 여부 확인

기존에 투표 기간 만료로 인해 페이지에서 투표가 불가능했던 상황에서 burp suite를 이용하여 자바스크립트를 확인하고 그 중 그림 3-21과 같이 투표와 관련된 스크립트 내용을 수정한 결과 그림 3-22과 같이 투표에 성공한 모습을 확인할 수 있다.

3.7. 계정 정보 추측 및 대입

분류	코드	점검 항목
계정정보 추측 및 대입	BP-001 BP-002	취약한 패스워드 설정 여부 어플리케이션/장비 기본 패스워드 설정 여부

Copyright ⓒ 2022 By ngnicky All Rights Reserved.

표 3-7 계정정보 추측 및 대입 점검 항목

3.7.1. 체크리스트 검증

▫ 관리자 계정 기본값 사용 여부

웹 애플리케이션의 관리자 계정에 대한 패스워드가 초기값 또는 쉽게 추측 가능한 단순 문자열로 설정되어 있을 경우 발생하는 취약점이다. 공격자는 기본 계정 정보를 이용하여 별도의 인증 과정 없이 관리자 권한을 획득할 수 있으며, 이를 통해 시스템 전반에 대한 접근 및 제어가 가능해진다.



그림 3-23 관리자 페이지 로그인 시도 (admin/admin 입력)

위 그림 3-23과 같이 관리자 로그인 페이지(http://192.168.144.131/gm/admin/)에 접속하여 ID와 PASSWORD 모두 'admin'을 입력한 후 로그인을 시도하였다.



Copyright ⓒ 2022 By ngnicky All Rights Reserved.

그림 3-24 Burp Suite Request 패킷 — adminId=admin&adminPwd=admin 평문 전송 확인

위 그림 3-24는 Burp Suite를 통해 인터셉트한 로그인 요청 패킷의 Body 부분이다. adminId=admin&adminPwd=admin이 평문으로 전송되는 것을 확인할 수 있다.



그림 3-25 Burp Suite Response 패킷 — HTTP 200 OK 및 서버 버전 정보 노출

위 그림 3-25는 서버의 응답 패킷이다. HTTP/1.1 200 OK 응답과 함께 Server 헤더에 Apache/2.2.8, PHP/5.2.4, OpenSSL/0.9.8g 등 서버 버전 정보가 노출되고 있음을 확인하였다.



Copyright ⓒ 2022 By ngnicky All Rights Reserved.

그림 3-26 관리자 페이지 접근 성공 — 전체 주문 정보 열람 가능

위 그림 3-26과 같이 admin/admin 계정으로 관리자 페이지 로그인에 성공하였으며, 주문관리 화면에서 전체 회원의 주문 정보 및 개인정보를 열람할 수 있는 상태임을 확인하였다.

데이터베이스 내 패스워드 평문 저장 여부

관리자 패스워드가 데이터베이스에 해시 처리 없이 평문으로 저장될 경우, 데이터베이스 접근이 가능한 상황에서 계정 정보가 즉시 노출될 수 있다. b374k 웹쉘을 통해 데이터베이스에 직접 접근하여 admin 테이블의 데이터를 조회하였다.

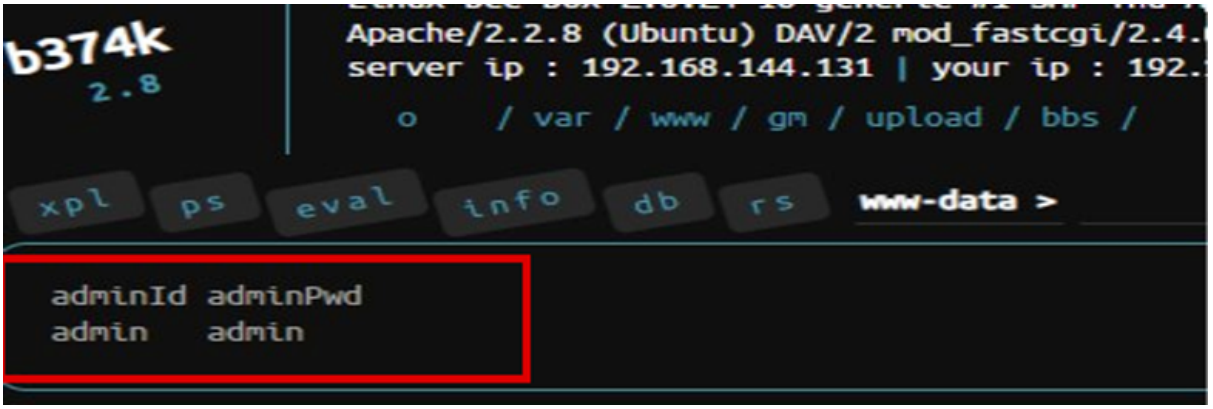


그림 3-27 b374k 웹쉘 DB 조회 — adminId, adminPwd 평문 저장 확인

위 그림 3–27과 같이 admin 테이블을 조회한 결과 adminId 컬럼에 'admin', adminPwd 컬럼에 'admin'이 해시 처리 없이 평문으로 저장되어 있는 것을 확인하였다.

3.8. 파라미터 조작

분류	코드	점검 항목
파라미터 조작	BP-006	URL 정보 내 파라미터 위/변조 여부
	BP-007	필드 값 조작에 따른 검증 여부

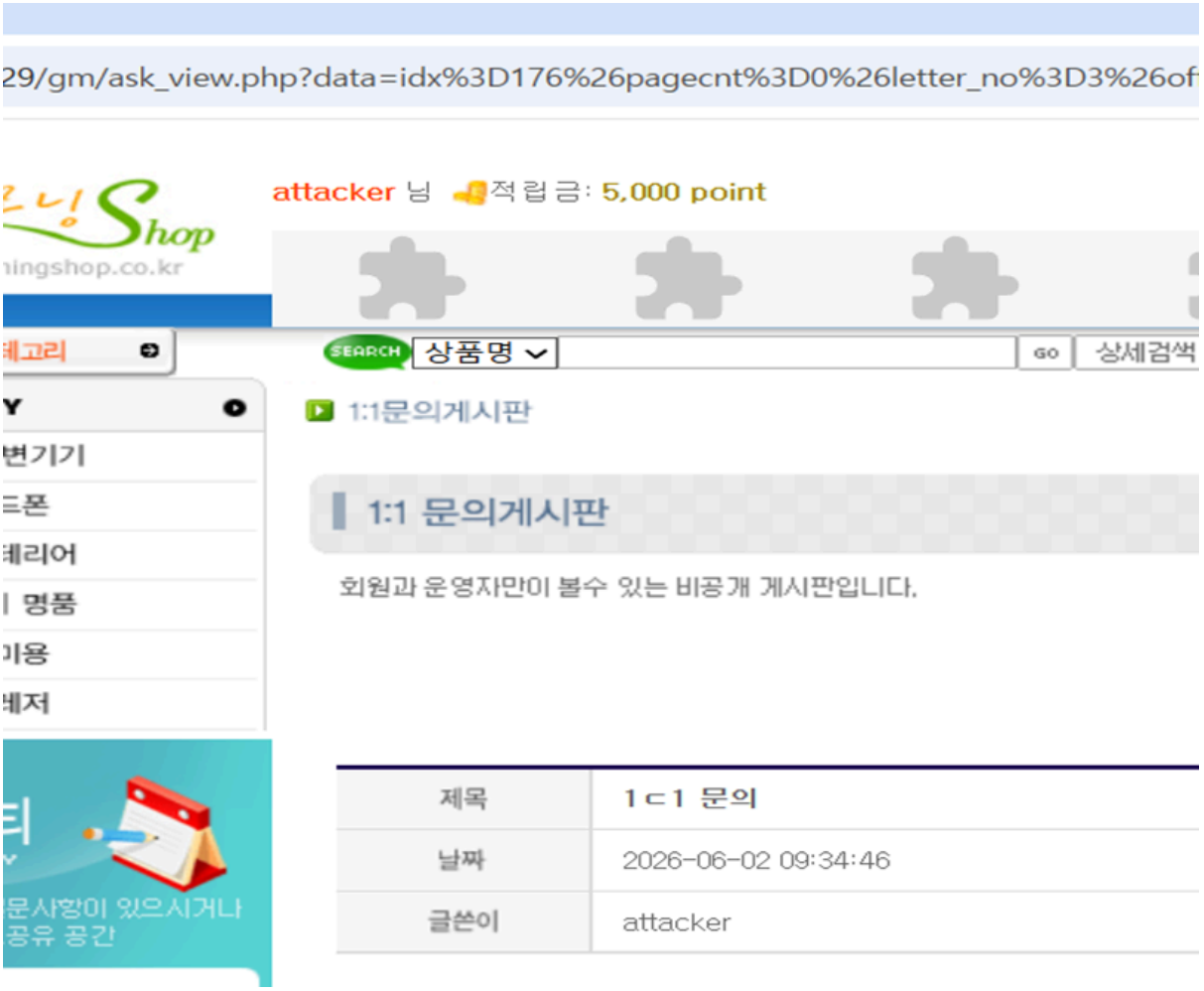
Copyright ⓒ 2022 By ngnicky All Rights Reserved.

표 3-8 파라미터 조작 점검 항목

3.8.1. 체크리스트 검증

URL 정보 내 파라미터 위/변조 여부

URL 내 GET 파라미터 값을 통해 사용자 식별, 권한 부여, 데이터 조회 등이 이루어지는 경우 해당 값을 임의로 위·변조하였을 때 서버 측에서 적절한 검증이 이루어지지 않을 경우 발생할 수 있는 취약점이다. 공격자가 URL 파라미터 값을 직접 수정하여 타 사용자의 정보를 조회하거나 권한 밖의 기능을 실행할 수 있으며, 이를 통해 개인정보 유출 및 불법적인 데이터 조작 등의 침해사고가 발생할 수 있다.



Copyright ⓒ 2022 By ngnicky All Rights Reserved.

그림 3-28 url내 idx값 변경 전 계정주인 확인



그림 3-29 url내 idx값 변경 후 계정주인 확인

그림 3-28과 같이 attacker의 계정으로 작성한 1:1 글의 idx값을 확인한 경우 해당 idx값을 다른 사용자의 화면에서 변경시켰을 때 그림 3-29의 결과와 같이 다른 사용자의 계정으로 attacker의 1:1 글을 확인할 수 있다. 이처럼 url내의 파라미터 값을 위/변조 하는 것으로 다른 사용자의 개인정보나 페이지에 접근 할 수 있다.

Copyright ⓒ 2022 By ngnicky All Rights Reserved.

필드 값 조작에 따른 검증 여부

웹 페이지의 숨김 필드(Hidden Field), 가격·수량·권한 등 클라이언트 측에 노출된 입력 필드 값을 임의로 조작하였을 때 서버 측에서 해당 값에 대한 유효성 검증이 미흡하게 구현되어 있을 경우 발생할 수 있는 취약점이다. 공격자가 브라우저 개발자 도구나 프록시 툴을 이용하여 필드 값을 변조함으로써 결제 금액 조작, 권한 상승, 타 사용자 정보 접근 등의 행위가 가능해지며, 이를 통해 금전적 피해 및 대규모 데이터 침해사고가 발생할 수 있다.



그림 3-30 상품구매 페이지의 필드 값 변경

Copyright ⓒ 2022 By ngnicky All Rights Reserved.

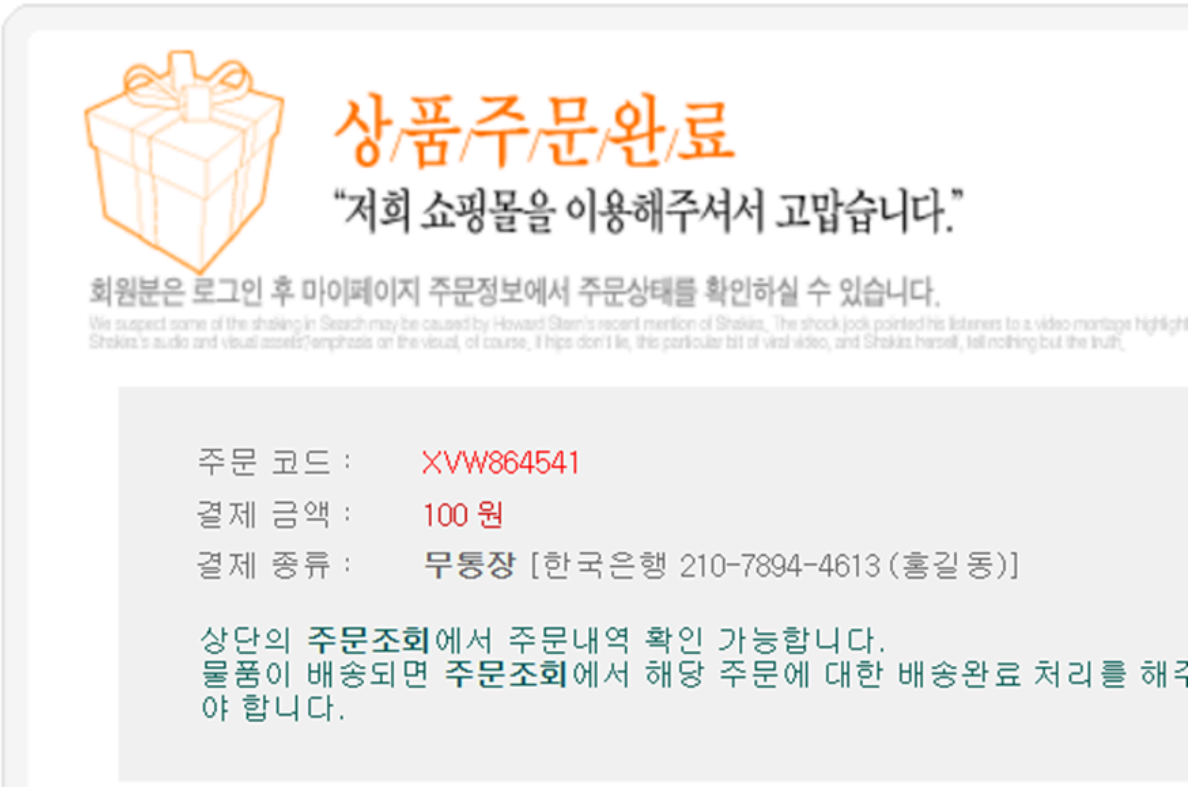


그림 3-31 상품구매 결과 값 확인

그림 3-30 과 같이 상품 구매 페이지에서 burp suite를 사용하여 패킷내 필드 값인 payM과 transM, totalM값을 변경함으로써 그림 3-31과 같이 원래 지불해야하는 가격 대신 공격자가 원하는 가격으로 변경하여 지출 비용을 마음대로 수정할 수 있다.

3.9. XSS (XST / TRACE)

분류	코드	점검 항목
XSS (CSRF) 취약점	BP-010	XST, TRACE 옵션 허용 여부

Copyright ⓒ 2022 By ngnicky All Rights Reserved.

	시나리오 기반 GM Shop 모의해킹 결과 보고서		
	Category	문서 버전	문서 최종 수정일
	Development Report	1.1.4	2026.06.04

표 3-9 XST 점검 항목

3.9.1. 체크리스트 검증

▫ XST, TRACE 옵션 허용 여부

HTTP TRACE 메서드는 클라이언트가 보낸 요청을 서버가 그대로 응답으로 되돌려주는(echo) 진단용 메서드이다. 이 메서드가 활성화되어 있으면 XST(Cross-Site Tracing) 공격을 통해 요청에 포함된 쿠키, 인증 헤더 등 민감 정보가 응답으로 반사되어 탈취될 수 있어, 사용 여부와 무관하게 비활성화하는 것이 권고된다.

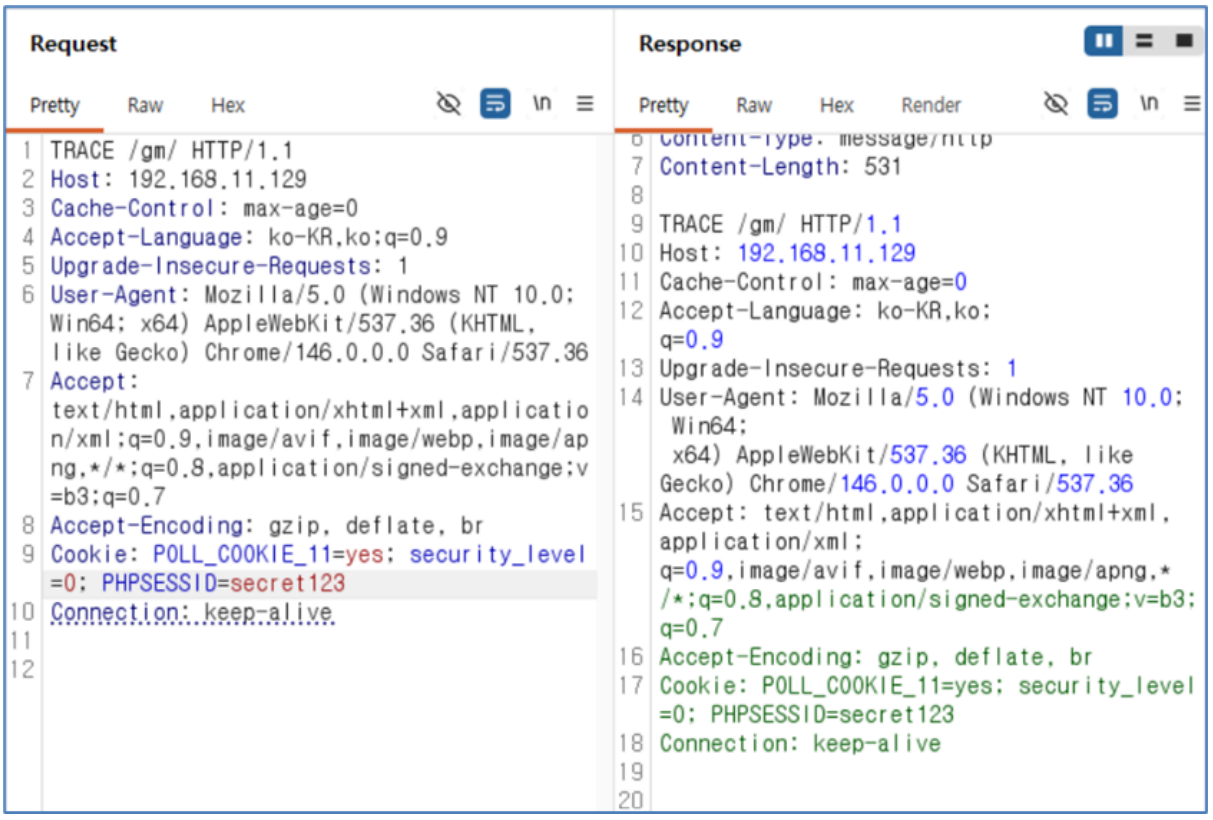


그림 3-32 TRACE 요청 시 요청 헤더 및 세션 쿠키 반사

위 그림과 같이 Burp Suite Repeater를 이용해 대상에 TRACE /gm/ 요청을 전송하면, 200 OK 응답과 함께 요청에 포함한 헤더가 본문(Content-Type: message/http)에 그대로 반사된다. 특히 요청에 포함한 Cookie 값에 세션 식별자(PHPSESSID)가 그대로 노출·반사되어, 공격자가 XST 공격으로 사용자 세션

Copyright ⓒ 2022 By ngnicky All Rights Reserved.

토큰을 탈취할 수 있는 상태임을 확인하였다

3.10. 페이지 내 중요 정보 노출

분류	코드	점검 항목
페이지내 중요 정보 노출	BP-016	중요 개인정보 노출 여부
	BP-017	쿠키 값 내 중요정보 유출 여부
	BP-018	데이터베이스 관련 정보 유출 여부
	BP-019	중요정보 평문 전송

표 3-10 페이지내 중요 정보 노출 점검 항목

3.10.1. 체크리스트 검증

중요 개인정보 노출 여부

웹 페이지 소스코드, 에러 메시지, 응답 데이터 등에 이름, 주민등록번호, 연락처, 이메일 등 중요 개인정보가 암호화 또는 마스킹 처리 없이 노출될 경우 발생할 수 있는 취약점이다. 공격자가 페이지 소스 분석이나 응답 패킷 확인을 통해 개인정보를 수집할 수 있으며, 이를 통해 개인정보 유출 및 2차 피해로 이어지는 침해사고가 발생할 수 있다.

쿠키 값 내 중요정보 유출 여부

사용자 인증 정보, 개인정보, 권한 정보 등 중요한 데이터가 암호화 없이 쿠키에 평문으로 저장되어 있을 경우 발생할 수 있는 취약점이다. 공격자가 브라우저 쿠키를 탈취하거나 네트워크 스니핑을 통해 쿠키 값을 획득할 경우 사용자의 민감한 정보가 그대로 노출될 수 있으며, 탈취한 정보를 이용한 계정 도용 및 개인정보 침해사고가 발생할 수 있다.

중요정보 평문 전송

로그인 정보, 개인정보, 결제 정보 등 중요한 데이터가 SSL/TLS 암호화 통신이 아닌 HTTP 평문 방식으로 전송될 경우 발생할 수 있는 취약점이다. 공격자가 네트워크 구간에서 패킷을 스니핑하여 전송 중인 중요 데이터를 그대로 획득할 수 있으며, 이를 통해 사용자 인증 정보 및 개인정보가 유출되는 침해사고가 발생할 수 있다.

Copyright ⓒ 2022 By ngnicky All Rights Reserved.

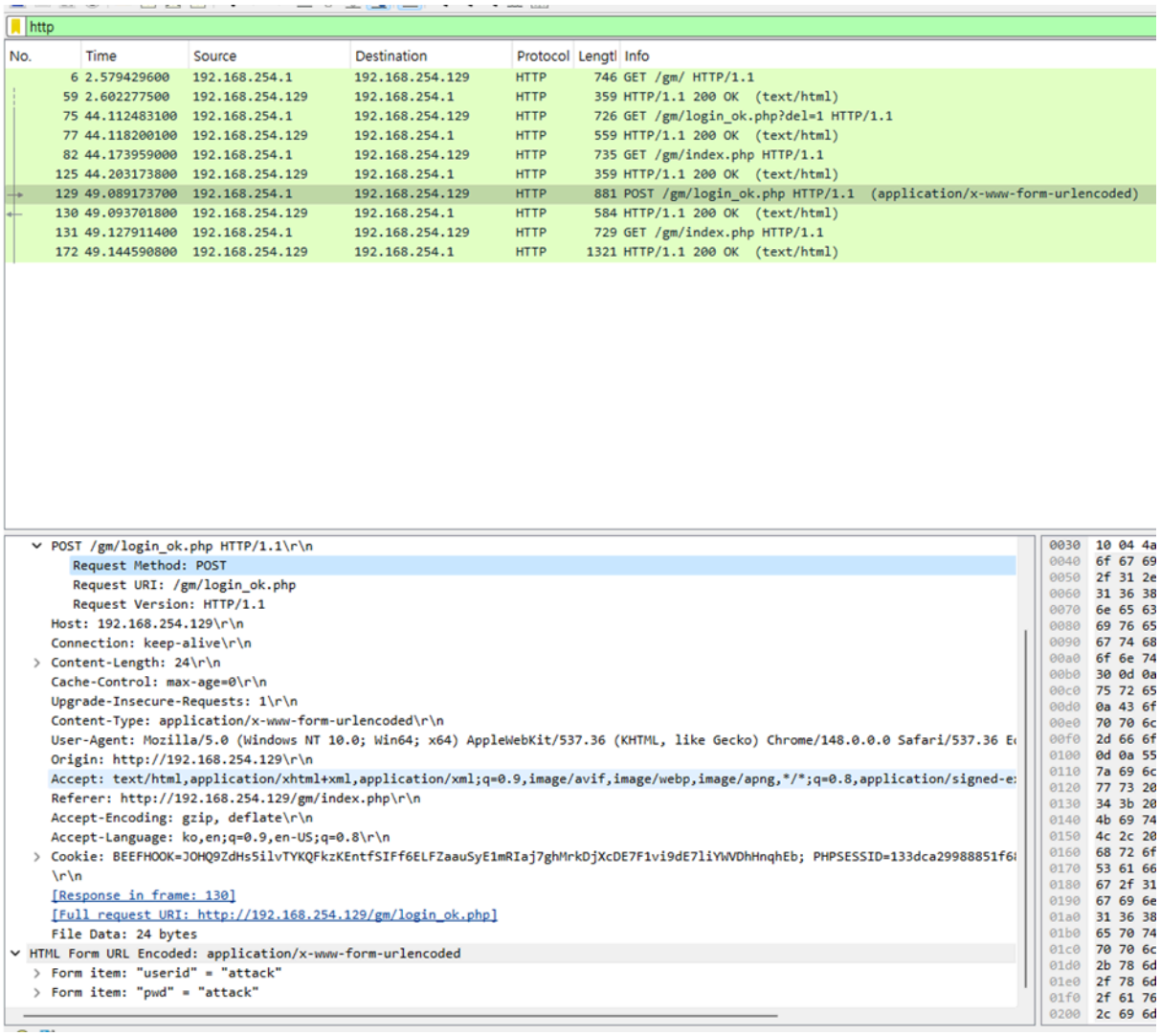


그림 3-33 와이어 샤크를 통한 패킷 확인

Gmshop 페이지에서 로그인을 할 때 와이어샤크를 통해 요청 패킷을 확인하게 되면 사용자의 아이디와 비밀번호, 쿠키 내부의 sessionID 등과 같은 중요한 정보들이 그림 3-33처럼 평문으로 노출되는 것을 확인할 수 있다.

데이터베이스 관련 정보 유출 여부

웹 애플리케이션의 에러 페이지, 응답 메시지, 소스코드 주석 등에 데이터베이스 종류, 버전, 테이블명, 쿼리문, 접속 정보 등이 노출될 경우 발생할 수 있는 취약점이다. 공격자가 노출된 데이터베이스 정보를 분석하여 SQL Injection 등 추가적인 공격에 활용할 수 있으며, 이를 통해 데이터베이스 전체가 탈취되는

Copyright ⓒ 2022 By ngnicky All Rights Reserved.

심각한 침해사고가 발생할 수 있다.



그림 3-34 페이지 내 '입력 결과

페이지의 입력 가능한 위치에 '을 추가한 후 전송했을 때 그림 3-34와 같이 에러 메시지와 함께 MYSQL 정보가 출력 되는 것을 확인할 수 있고 이를 통해 result.php파일의 경로도 확인할 수 있는 것을 알 수있다.

3.11. SQL Injection

분류	코드	점검 항목
SQL Injection	BP-027	SQL Injection 허용 여부

표 3-11 SQL Injection 점검 항목

3.11.1. 체크리스트 검증

사용자 입력 기능 입력값 검증 미흡 여부

사용자 입력 기능에 입력값에 대한 필터링 및 SQL 질의문 제어가 적절하게 이루어지지 않을 경우, 공격자가 임의의 SQL 구문을 삽입하여 데이터베이스 내 중요 정보를 조회할 수 있는 취약점이 발생할 수

Copyright ⓒ 2022 By ngnicky All Rights Reserved.

있다.

SQL Injection 취약점 여부 확인을 위해 다양한 입력값 검증을 수행하였다. 초기 단계에서는 ‘, ‘ or 1=1 # 등의 구문을 이용하여 SQL 오류 및 조건 우회 가능 여부를 확인하였으며 이후 order by, union select 구문을 통해 컬럼 개수 및 출력 위치를 식별하였다. 또한 information_schema, @@version, database(), user() 등을 활용하여 데이터베이스 환경 정보 및 테이블 구조 정보 확인이 가능한 것을 확인하였다.

점검 과정에서 우편번호 검색 입력창에 아래와 같은 UNION 기반 SQL Injection 구문을 삽입하여 요청을 수행하였다.

```
0' union select 1, adminId, adminEmail, '---', adminPwd, '', '' from admin #
```

해당 구문은 기존 SQL 질의 결과와 관리자(admin) 테이블의 데이터를 결합하여 출력하도록 구성된 UNION SELECT 구문이다. 입력값 검증이 미흡할 경우 공격자는 별도의 인증 절차 없이 데이터베이스 내 중요 정보를 조회할 수 있다.



그림 3-35 SQL Injection 데이터 탈취 성공

위 그림 3-35와 같이 SQL Injection 구문 실행 결과 관리자 계정 정보가 정상적으로 조회되는 것을 확인하였다.

Copyright ⓒ 2022 By ngnicky All Rights Reserved.

로그인 처리 시 예외처리 미흡 여부

로그인 기능에서 입력값에 대한 검증 및 예외처리가 적절하게 수행되지 않을 경우 발생할 수 있는 취약점이다. 일반적으로 ID 또는 Password 입력값에 특수문자(')가 포함되면 SQL 구문 오류가 발생할 수 있으며 이에 대한 예외처리가 미흡할 경우 비정상적인 인증 우회 현상이 발생할 수 있다.

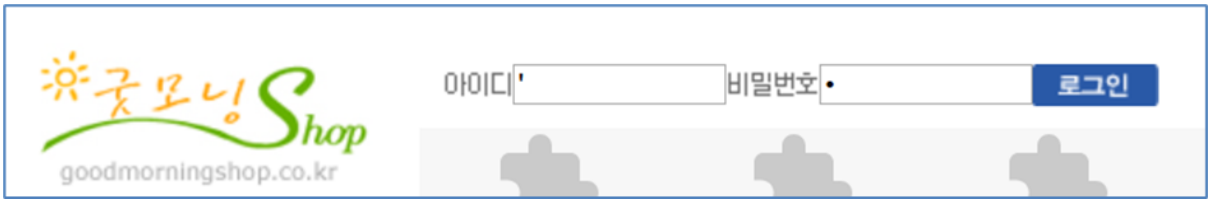


그림 3-36 SQL Injection 로그인 시도

위 그림 3-36를 보면 ID 및 Password 입력창에 특수문자(')를 입력한 상태로 로그인을 시도하였을 때 SQL 구문이 비정상적으로 처리되어 문제가 발생하는 것을 확인할 수 있다. 일반적으로 이러한 경우, 로그인 실패 처리 또는 오류 메시지 출력 후 인증이 차단되어야 한다.



그림 3-37 Burp Suite 응답 패킷 결과

하지만 Burp Suite를 통해 응답 패킷을 확인한 결과, 그림 3-37과 같이 오류 메시지가 일시적으로 출력된 이후 곧바로 로그인 성공 화면으로 이동하는 현상이 확인되었다.

로그인 처리 과정에서 SQL 실행 결과에 대한 예외처리가 적절하게 구현되어 있지 않기 때문이다. SQL 구문 오류로 인해 정상적인 MySQL Result 객체가 반환되지 않았음에도 PHP 로직에서 해당 결과값에 대한 검증 없이 다음 인증 절차를 계속 수행하면서 로그인 성공 처리되는 것으로 판단된다.

Copyright ⓒ 2022 By ngnicky All Rights Reserved.



그림 3-37 로그인 성공

위 그림 3-37은 특수문자(') 입력 후 SQL 오류가 발생하였음에도 불구하고 정상적으로 로그인에 성공한 모습이다.

3.12. 파일 업로드 취약점

분류	코드	점검 항목
파일 업로드 취약점	BP-024	입력 값 검증 미흡으로 파일 업로드 공격 여부

표 3-12 파일 업로드 점검 항목

3.12.1. 체크리스트 검증

악성 파일 업로드 제한 여부

파일 업로드 기능에서 확장자 및 파일 유형에 대한 검증이 적절하게 수행되지 않을 경우 발생할 수 있는 취약점이다. 일반적으로 PHP와 같은 서버 스크립트 파일은 업로드가 제한되어야 하며 업로드 이후 서버에서 실행되지 않도록 설정되어야 한다.

Copyright ⓒ 2022 By ngnicky All Rights Reserved.

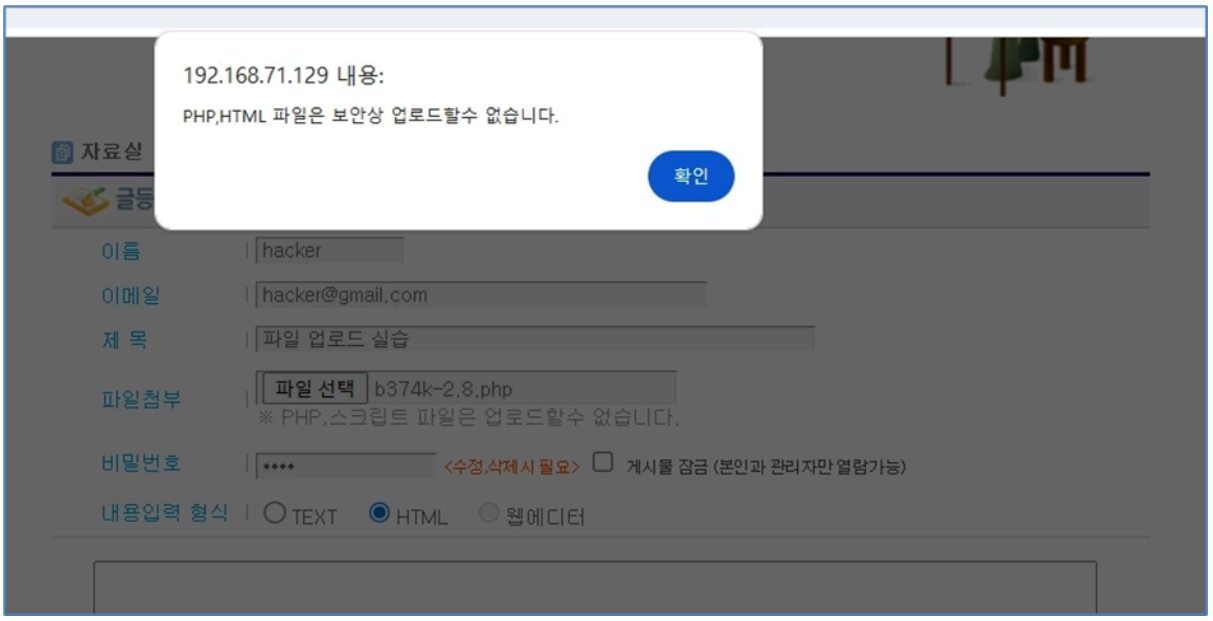


그림 3-38 PHP 파일 업로드 차단

위 그림 3-36을 보면 PHP 파일 업로드 시 확장자 검증 로직에 의해 업로드가 차단되는 것을 확인할 수 있다. 하지만 해당 검증은 클라이언트 측(JavaScript) 검증 로직에 의존하고 있는 것으로 확인되었다.

Burp Suite를 이용하여 응답 데이터를 분석한 결과, 파일 업로드 제한과 관련된 JavaScript 검증 구문이 포함되어 있었으며 해당 검증 구문을 주석 처리한 이후 PHP 파일 업로드가 정상적으로 수행되는 것을 확인하였다.

Copyright ⓒ 2022 By ngnicky All Rights Reserved.

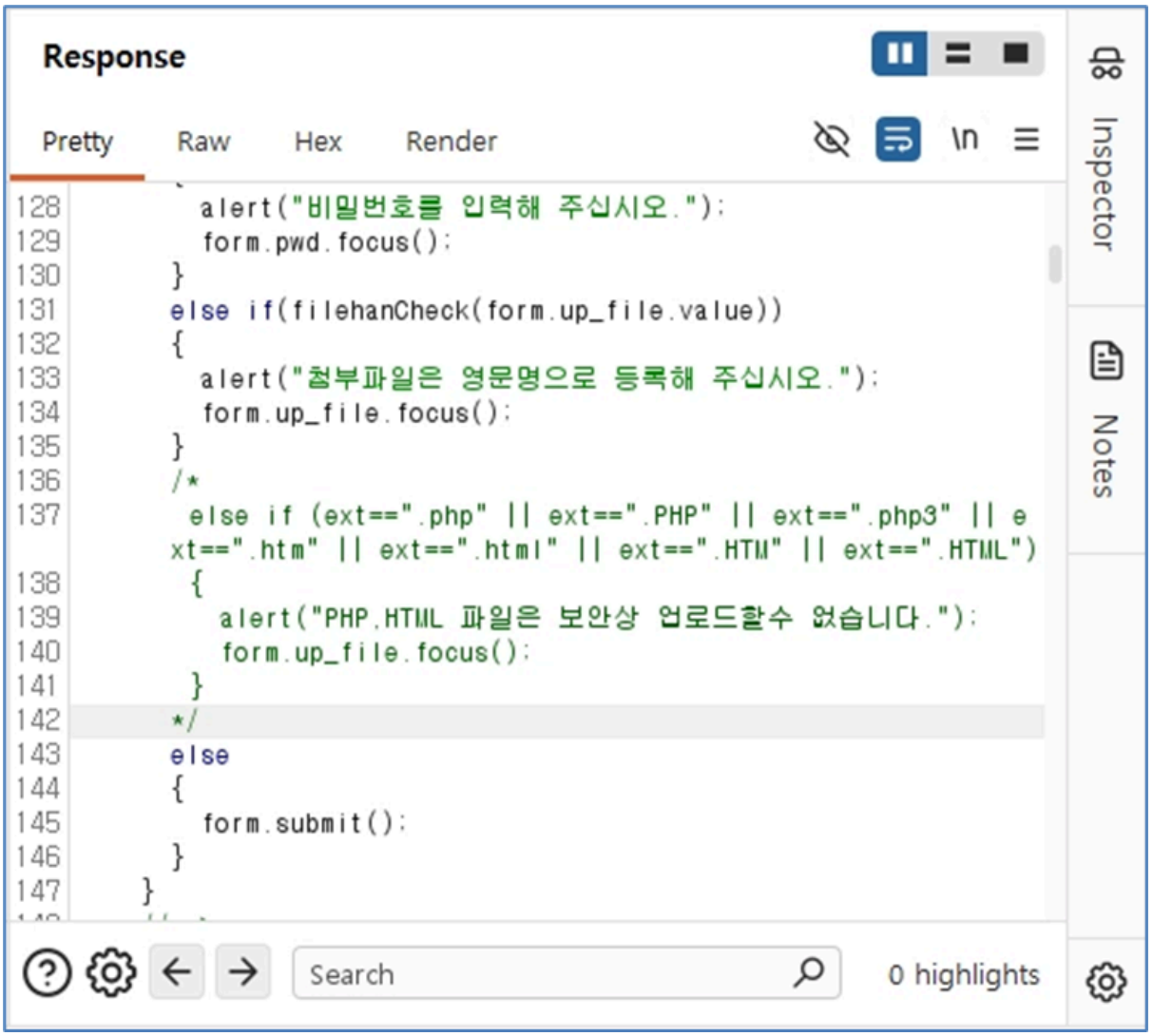


그림 3-39 Burp Suite를 이용한 검증 로직 주석처리

그림 3-37는 Burp Suite에서 응답 데이터 내 파일 업로드 제한 구문을 주석 처리한 모습이다. 클라이언트 측 검증 로직이 비활성화되면서 PHP 파일 업로드 제한 기능이 우회되는 것을 확인할 수 있다.

Copyright ⓒ 2022 By ngnicky All Rights Reserved.

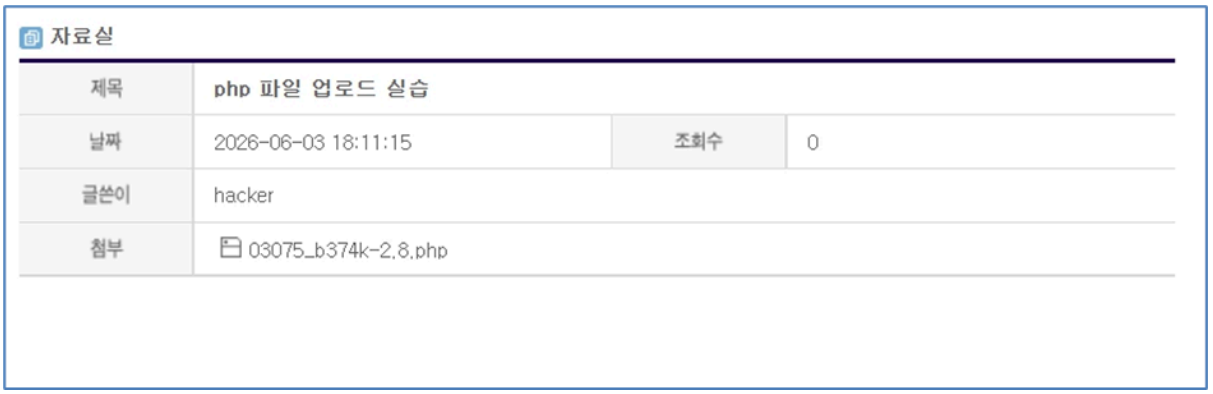


그림 3-40 PHP 파일 업로드 성공

Copyright ⓒ 2022 By ngnicky All Rights Reserved.

4. 취약점 대응방안

취약점 대응방안은 안전행정부와 한국인터넷진흥원에서 발행한 주요정보통신기반시설 기술적 취약점 분석 평가 방법 상세가이드를 기반으로 작성했다. 대응방안은 상세 수행 내역에서 도출된 취약점과 순서는 동일하며, 관리적, 기술적, 물리적 그리고 소스코드 관점의 보안을 설명한다.

4.1. 에러 메시지 정보 노출

4.1.1. 취약점 개요

웹 애플리케이션에서 발생하는 오류 메시지에 데이터베이스 쿼리 구조, 서버 내부 경로, 파일명, 라인 번호 등의 시스템 정보가 포함되어 사용자 화면에 노출될 경우 공격자가 이를 시스템 구조 분석 및 추가 공격에 활용할 수 있는 취약점이다.

4.1.2. 권고사항

◘ 점검 방법

검색, 로그인, 게시판 등 사용자 입력을 처리하는 모든 페이지에서 비정상적인 값을 입력하였을 때 상세 오류 메시지가 출력되는지 확인한다.

- SQL 구문 오류 유발 시 DB 관련 에러 메시지 출력 여부 확인
- PHP Warning, Notice, Fatal Error 등의 노출 여부 확인
- 서버 내부 경로 및 파일명 노출 여부 확인
- 응답 헤더의 Server 항목에 버전 정보 포함 여부 확인

점검 예시	검색창 입력: ' (따옴표 하나) 검색창 입력: 1' OR '1'='1 URL 직접 입력: ?searchstring='

Copyright ⓒ 2022 By ngnicky All Rights Reserved.

표 4-1 에러 메시지 점검 방법

□ 보안 설정 방법

- php.ini에서 display_errors = Off 설정으로 운영 환경 에러 메시지 출력 비활성화
- 사용자에게는 '요청을 처리할 수 없습니다' 등 일반화된 메시지만 출력
- 상세 오류 내용은 서버 로그(log_errors = On)에만 기록하여 관리자만 확인 가능하도록 설정
- try-catch 등 예외 처리 로직을 구현하여 시스템 정보가 외부로 노출되지 않도록 처리
- Apache 설정에서 ServerTokens Prod, ServerSignature Off 설정으로 서버 버전 정보 노출 차단

표 4-2 에러 메시지 정보 노출 보안 설정 방법

4.2. 최신 취약점 미패치

4.2.1. 취약점 개요

서버에 설치된 어플리케이션(웹 서버, 스크립트 엔진, 암호화 라이브러리 등)의 버전이 오래되어 보안 패치가 적용되지 않은 경우, 공개된 알려진 취약점을 통해 시스템이 침해될 수 있다. 또한 버전 정보가 외부로 노출되면 공격자가 공격 대상을 특정하고 공격 벡터를 선정하는 데 악용될 수 있으므로, 최신 버전으로의 패치와 버전 정보 비노출이 필요하다.

4.2.2. 권고사항

□ 점검 방법

응답 헤더(Server, X-Powered-By 등) 및 버전 탐지 도구(Nmap, Nikto)를 통해 노출되는 버전 정보를 확인하고, 해당 버전에 대한 공개 취약점(CVE) 존재 여부를 점검한다.

- 응답 헤더 및 버전 탐지 도구로 Apache, PHP, OpenSSL 등 구성 소프트웨어의 버전을 확인
- 공개된 취약점(CVE) 및 익스플로잇 존재 여부를 점검한다.

Copyright ⓒ 2022 By ngnicky All Rights Reserved.

□ 보안 설정 방법

- **Apache, PHP, OpenSSL 등 사용 중인 소프트웨어를 보안 패치가 적용된 지원 버전으로 업데이트한다.**
- **Apache `httpd.conf`(또는 `apache2.conf`)에 `ServerTokens Prod`, `ServerSignature Off` 를 설정하여 버전 정보 노출을 차단한다.**
- **PHP `php.ini`에서 `expose_php = Off` 로 설정하여 `X-Powered-By` 헤더 노출을 차단한다. 불필요한 모듈·서비스를 비활성화하고 주기적인 패치 관리 체계를 수립한다.**

4.3. 디렉터리 리스팅 취약

4.3.1. 취약점 개요

디렉터리 리스팅은 웹 서버가 요청된 디렉터리에 기본 문서가 없을 때 파일 목록을 자동으로 출력하는 설정으로 인해 발생한다. 노출된 파일 목록을 통해 소스 코드, 설정 파일, 백업 파일 등의 위치가 드러나 추가 공격의 발판이 되므로, 디렉터리 인덱싱 기능을 비활성화해야 한다.

4.3.2. 권고사항

□ 점검 방법

응답 헤더(Server, X-Powered-By 등) 및 버전 탐지 도구(Nmap, Nikto)를 통해 노출되는 버전 정보를 확인하고, 해당 버전에 대한 공개 취약점(CVE) 존재 여부를 점검한다.

- 서비스 내 디렉터리 경로(예: `/lib/`, `/upload/`, `/admin/` 등)에 직접 접근하여 파일 목록이 노출되는지 확인하고, 디렉터리 스캔 도구로 인덱싱이 허용된 디렉터리를 점검한다.

□ 보안 설정 방법

- Apache 설정 파일(또는 `.htaccess`)의 해당 디렉터리 설정에서 `Options -Indexes` 를 적용하여 디렉터리 인덱싱 기능을 비활성화한다.
- 인덱싱이 필요한 경우를 제외한 모든 디렉터리에 기본 문서(index.html 등)를 배치한다. 웹 루트 하위에 소스·설정·백업 파일 등 노출되어서는 안 되는 파일을 두지 않는다.

Copyright ⓒ 2022 By ngnicky All Rights Reserved.

4.4. 불필요 파일 존재 및 파일 다운로드

4.4.1. 취약점 개요

서비스 운영에 사용되지 않는 데이터베이스 스크립트, 사이트 백업 파일, 설계 문서, 테스트 페이지 등이 웹에서 접근 가능한 경로에 방치될 경우, 공격자가 이를 직접 다운로드하여 내부 구조 및 민감 정보(소스코드, DB 접속 정보, 개인정보 등)를 획득할 수 있다. 불필요한 파일은 삭제하거나 웹에서 접근할 수 없는 위치로 이전해야 한다..

.

4.4.2. 권고사항

◘ 점검 방법

점검 방법 웹 루트 내 불필요 파일의 존재 및 직접 다운로드 가능 여부를 확인한다.

- 웹 루트 하위에 .sql, .bak, .zip, .tar.gz, .txt 등 백업·스크립트·설계 문서 및 phpinfo.php 등 테스트 페이지가 존재하는지 확인한다.
- 해당 파일에 외부에서 직접 접근 및 다운로드가 가능한지 점검한다.
- 파일명 파라미터를 사용하는 다운로드 기능에 대해 경로 조작(Path Traversal) 가능 여부를 점검한다.

◘ 보안 설정 방법

- 서비스 운영에 불필요한 파일(데이터베이스 스크립트, 백업 파일, 설계 문서, 테스트 페이지 등)은 즉시 삭제한다.
- 운영상 보관이 필요한 파일은 웹 루트 외부의 접근 불가능한 경로에 보관한다. 부득이 웹 루트에 두어야 할 경우 접근 제어 설정으로 외부 접근을 차단한다.
- 데이터베이스에 저장되는 패스워드 등 인증 정보는 평문이 아닌 안전한 해시 알고리즘으로
- 저장한다. 파일 다운로드 기능을 운영할 경우 파일명·경로 입력값을 화이트리스트로 검증한다.

Copyright ⓒ 2022 By ngnicky All Rights Reserved.

4.5.1. 페이지 내 관리자 페이지 링크 여부

4.5.1.1. 취약점 개요

웹 페이지의 소스코드, 주석, 숨겨진 링크 등에 관리자 페이지 경로가 노출되어 있을 경우 발생할 수 있는 취약점이다. 공격자가 페이지 소스를 분석하여 관리자 페이지 URL을 획득할 수 있으며, 이를 통해 관리자 페이지에 직접 접근을 시도하거나 추가적인 공격의 발판으로 활용될 수 있다.

4.5.1.2. 권고사항

점검 방법

웹 페이지 소스코드 내 관리자 페이지와 관련된 링크 또는 경로 정보가 노출되어 있는지 확인한다.

- 소스코드 내 admin, manager, administrator 등의 키워드 포함 여부 확인
- 주석 처리된 관리자 페이지 경로 노출 여부 확인
- JavaScript 파일 내 관리자 관련 경로 포함 여부 확인 (예: <script src="./script/admin.js">)

보안 설정 방법

소스코드 내 관리자 페이지와 관련된 경로 및 링크 정보를 제거하고, 아래와 같은 보안 조치를 적용하여야 한다.

- 웹 페이지 소스코드 및 JavaScript 파일 내 관리자 관련 경로 및 키워드 제거
- 관리자 페이지 URL을 유추하기 어려운 명칭으로 변경
- 불필요한 주석 및 숨겨진 링크 제거

4.5.2 관리자 페이지 접근 여부

4.5.2.1. 취약점 개요

인증 및 접근 제어가 미흡하게 구현되어 일반 사용자 또는 비인가 사용자가 관리자 페이지에 접근 가능할 경우 발생할 수 있는 취약점이다. 공격자가 관리자 기능에 무단으로 접근하여 회원 정보 열람·수정·삭제, 시스템 설정 변경 등 권한을 남용할 수 있으며, 이는 대규모 개인정보 유출 및 서비스 전체의 침해사고로

Copyright ⓒ 2022 By ngnicky All Rights Reserved.

이어질 수 있다.

4.5.2.2 권고사항

점검 방법

관리자 페이지 URL에 일반 사용자 계정 또는 비인가 상태로 직접 접근하여 정상적인 차단이 이루어지는지 확인한다.

- 비로그인 상태에서 관리자 페이지 URL 직접 입력 후 접근 가능 여부 확인
- 일반 사용자 계정으로 로그인 후 관리자 페이지 접근 가능 여부 확인
- admin, administrator, manager 등 추측 가능한 URL 패턴으로 접근 시도

보안 설정 방법

관리자 페이지에 대한 접근 제어를 강화하고, 아래와 같은 보안 조치를 적용하여야 한다.

- 관리자 페이지 접근 시 서버 측에서 권한 검증 로직 구현
- 관리자 계정에 대한 IP 접근 제한 적용
- 관리자 페이지 접근 시 이중 인증(2FA) 적용
- 관리자 페이지 접근 로그 기록 및 모니터링 체계 구축

4.5.3 비인가 페이지 강제 호출 여부

4.5.3.1 취약점 개요

인증되지 않은 사용자가 URL을 직접 입력하거나 조작하여 접근이 제한된 페이지를 강제로 호출할 수 있을 경우 발생할 수 있는 취약점이다. 서버 측에서 인증 및 권한 검증이 적절히 이루어지지 않을 경우, 공격자가 로그인 절차를 우회하여 개인정보 조회 페이지, 결제 처리 페이지 등 민감한 기능에 접근할 수 있으며, 이를 통한 정보 유출 및 불법적인 기능 실행이 가능해진다.

4.5.3.2. 권고사항

점검 방법

비로그인 상태 또는 권한이 없는 계정으로 접근 제한 페이지의 URL을 직접 입력하여 강제 호출이

Copyright ⓒ 2022 By ngnicky All Rights Reserved.

가능한지 확인한다.

- 로그인 후 접근 가능한 페이지 URL을 비로그인 상태에서 직접 호출하여 접근 가능 여부 확인
- 일반 사용자 권한으로 관리자 전용 기능 페이지 강제 호출 여부 확인
- 단계별 프로세스(회원가입, 결제 등) 중간 페이지 직접 호출 가능 여부 확인

보안 설정 방법

모든 페이지 요청에 대해 서버 측에서 인증 및 권한을 검증하고, 아래와 같은 보안 조치를 적용하여야 한다.

- 모든 페이지에 서버 측 세션 및 권한 검증 로직 구현
- 비인가 접근 시 로그인 페이지로 리다이렉트 처리
- 단계별 프로세스에 대한 순서 검증 로직 구현

4.6.1 쿠키 재사용 (Replay Attack) 여부

4.6.1.1. 취약점 개요

로그아웃 이후 또는 세션 만료 후에도 이전에 발급된 쿠키 값이 무효화되지 않고 재사용 가능하도록 웹 로직이 구현되어 있을 경우 발생할 수 있는 취약점이다. 공격자가 네트워크 스니핑이나 XSS 등을 통해 탈취한 쿠키를 재사용하면 정상적인 인증 절차 없이 피해자의 계정으로 세션을 재연결할 수 있으며, 이를 통해 개인정보 유출 및 계정 탈취 등의 침해사고가 발생할 수 있다.

4.6.1.2. 권고사항

점검 방법

로그인 후 발급된 쿠키 값을 저장한 뒤 로그아웃 또는 세션 만료 후 해당 쿠키를 재사용하여 접근이 가능한지 확인한다.

- 로그인 후 쿠키 값을 복사하여 저장
- 로그아웃 후 저장된 쿠키 값을 삽입하여 인증 페이지 접근 가능 여부 확인
- 세션 만료 후 동일한 쿠키 값으로 재접근 가능 여부 확인

Copyright ⓒ 2022 By ngnicky All Rights Reserved.

보안 설정 방법

로그아웃 및 세션 만료 시 쿠키를 즉시 무효화하고, 아래와 같은 보안 조치를 적용하여야 한다.

- 로그아웃 시 서버 측 세션 즉시 삭제 및 쿠키 무효화 처리
- 세션 유효기간 설정 및 만료 시 자동 무효화 처리
- 쿠키에 HttpOnly, Secure 속성 적용
- 세션 ID 재발급 로직 구현 (로그인 시마다 새로운 세션 ID 발급)

4.6.2 중요 페이지 세션/인증/접근 체크 여부

4.6.2.1. 취약점 개요

마이페이지, 결제 페이지, 개인정보 변경 페이지 등 중요한 기능을 수행하는 페이지에서 세션 유효성 및 인증 여부를 적절히 검증하지 않을 경우 발생할 수 있는 취약점이다. 서버 측에서 매 요청마다 세션 및 인증 상태를 확인하지 않을 경우, 공격자가 인증 절차를 우회하여 중요 페이지에 접근할 수 있으며, 개인정보 열람 및 무단 거래 등 심각한 피해로 이어질 수 있다.

4.6.2.2. 권고사항

점검 방법

중요 기능 페이지에 대해 세션 및 인증 검증이 적절히 이루어지는지 확인한다.

- 세션 삭제 또는 만료 후 중요 페이지 직접 접근 가능 여부 확인
- 타 사용자의 세션으로 중요 페이지 접근 가능 여부 확인
- 중요 기능(정보 변경, 결제 등) 수행 시 재인증 여부 확인

보안 설정 방법

중요 페이지에 대한 세션 및 인증 검증을 강화하고, 아래와 같은 보안 조치를 적용하여야 한다.

- 모든 중요 페이지 요청 시 서버 측 세션 유효성 검증 로직 구현
- 중요 정보 변경(비밀번호, 결제 등) 시 재인증 절차 적용
- 일정 시간 미사용 시 자동 로그아웃 처리

Copyright ⓒ 2022 By ngnicky All Rights Reserved.

4.6.3클라이언트 인증 우회 여부 (Javascript 우회)

4.6.3.1. 취약점 개요

입력값 검증, 접근 제어, 인증 로직 등이 서버가 아닌 클라이언트 측 JavaScript에만 구현되어 있을 경우 발생할 수 있는 취약점이다. 공격자가 브라우저 개발자 도구나 프록시 툴을 이용하여 JavaScript 코드를 비활성화하거나 요청 값을 직접 조작함으로써 클라이언트 측 검증 로직을 손쉽게 우회할 수 있으며, 이를 통해 비정상적인 데이터 입력 및 인증 절차 없이 제한된 기능에 접근하는 침해사고가 발생할 수 있다.

4.6.3.2. 권고사항

점검 방법

브라우저 개발자 도구 또는 프록시 툴을 이용하여 JavaScript 검증 로직을 우회할 수 있는지 확인한다.

- 브라우저에서 JavaScript 비활성화 후 인증 및 입력값 검증 우회 가능 여부 확인
- 프록시 툴을 이용하여 클라이언트에서 전송되는 요청 값 직접 조작 후 서버 처리 여부 확인
- 소스코드 내 JavaScript로만 구현된 인증 및 검증 로직 존재 여부 확인

보안 설정 방법

모든 인증 및 입력값 검증 로직을 서버 측에서 처리하도록 구현하고, 아래와 같은 보안 조치를 적용하여야 한다.

- 클라이언트 측 JavaScript 검증과 별개로 서버 측 검증 로직 이중 구현
- 사용자 입력값에 대한 서버 측 화이트리스트 기반 유효성 검증 적용
- 중요 인증 로직의 클라이언트 측 노출 최소화

4.7. 계정정보 추측 및 대입

4.7.1. 취약점 개요

관리자 계정의 초기 패스워드가 변경되지 않거나 단순한 문자열로 설정되어 있을 경우 공격자가 쉽게 계정 정보를 추측하여 인증을 우회할 수 있는 취약점이다. 또한 패스워드가 해시 처리 없이 평문으로 데이터베이스에 저장될 경우 데이터베이스 접근 시 계정 정보가 즉시 노출되며 추가 공격으로 이어질 수

Copyright ⓒ 2022 By ngnicky All Rights Reserved.

있다.

4.7.12. 권고사항

▫ 점검 방법

관리자 페이지 로그인 시 admin/admin, admin/1234, admin/password 등 기본값으로 로그인이 가능한지 확인한다. 또한 데이터베이스 내 패스워드 저장 방식이 평문인지 해시 처리되어 있는지 점검한다.

점검 예시	ID: admin / Password: admin ID: admin / Password: 1234 ID: admin / Password: password ID: root / Password: root

표 4-3 계정정보 추측 테스트 입력값 예시

▫ 보안 설정 방법

- 초기 패스워드를 추측하기 어려운 복잡한 문자열로 즉시 변경
- 패스워드는 반드시 bcrypt, SHA-256 등 단방향 해시 함수로 암호화하여 저장
- 패스워드 정책 적용: 영문 대소문자, 숫자, 특수문자 조합 8자리 이상 필수
- 관리자 계정 로그인 실패 횟수 제한 및 계정 잠금 정책 적용
- 데이터베이스 내 평문으로 저장된 패스워드를 해시값으로 즉시 교체

표 4-4 계정정보 추측 및 대입 보안 설정 방법

4.8.1 URL 정보 내 파라미터 위/변조 여부

4.8.1.1. 취약점 개요

URL 내 GET 파라미터 값을 통해 사용자 식별, 권한 부여, 데이터 조회 등이 이루어지는 경우 해당 값을 임의로 위·변조하였을 때 서버 측에서 적절한 검증이 이루어지지 않을 경우 발생할 수 있는 취약점이다.

Copyright ⓒ 2022 By ngnicky All Rights Reserved.

공격자가 URL 파라미터 값을 직접 수정하여 타 사용자의 정보를 조회하거나 권한 밖의 기능을 실행할 수 있으며, 이를 통해 개인정보 유출 및 불법적인 데이터 조작 등의 침해사고가 발생할 수 있다.

4.8.1.2. 권고사항

점검 방법

URL 내 파라미터 값을 임의로 변조하여 타 사용자의 정보 또는 권한 밖의 데이터에 접근 가능한지 확인한다.

- URL 내 사용자 식별 파라미터(idx, uid, no 등) 값을 변조하여 타 사용자 정보 접근 가능 여부 확인
- 권한 관련 파라미터 값 변조 후 권한 상승 가능 여부 확인
- 프록시 툴을 이용한 GET 파라미터 값 변조 후 서버 측 검증 여부 확인

보안 설정 방법

URL 파라미터를 통한 데이터 접근 시 서버 측에서 권한 검증을 수행하고, 아래와 같은 보안 조치를 적용하여야 한다.

- 서버 측에서 요청한 사용자의 세션과 요청 데이터의 소유자 일치 여부 검증 로직 구현
- 직접 객체 참조(IDOR) 방지를 위한 간접 참조 방식 적용
- 파라미터 값에 대한 서버 측 유효성 및 권한 검증 로직 구현

4.8.2 필드 값 조작에 따른 검증 여부

4.8.2.1. 취약점 개요

웹 페이지의 숨김 필드(Hidden Field), 가격·수량·권한 등 클라이언트 측에 노출된 입력 필드 값을 임의로 조작하였을 때 서버 측에서 해당 값에 대한 유효성 검증이 미흡하게 구현되어 있을 경우 발생할 수 있는 취약점이다. 공격자가 브라우저 개발자 도구나 프록시 툴을 이용하여 필드 값을 변조함으로써 결제 금액 조작, 권한 상승, 타 사용자 정보 접근 등의 행위가 가능해지며, 이를 통해 금전적 피해 및 대규모 데이터 침해사고가 발생할 수 있다.

Copyright ⓒ 2022 By ngnicky All Rights Reserved.

4.8.2.2. 권고사항

점검 방법

브라우저 개발자 도구 또는 프록시 툴을 이용하여 숨김 필드 및 입력 필드 값을 변조한 후 서버에서 정상 처리되는지 확인한다.

- 숨김 필드(Hidden Field) 값 변조 후 서버 측 검증 여부 확인
- 가격, 수량, 권한 등 중요 필드 값 변조 후 정상 처리 여부 확인
- 프록시 툴을 이용한 POST 파라미터 값 변조 후 서버 측 처리 여부 확인

보안 설정 방법

클라이언트에서 전달되는 모든 필드 값에 대해 서버 측 검증을 수행하고, 아래와 같은 보안 조치를 적용하여야 한다.

- 가격, 수량 등 중요 데이터는 클라이언트가 아닌 서버 측 데이터베이스 값을 기준으로 처리
- 숨김 필드에 중요 데이터를 저장하지 않도록 설계 변경
- 모든 입력 필드에 대한 서버 측 화이트리스트 기반 유효성 검증 로직 구현

4.9. XSS (XST / TRACE)

4.9.1. 취약점 개요

HTTP TRACE 메서드가 활성화되어 있을 경우 발생할 수 있는 취약점이다. TRACE 메서드는 요청을 그대로 응답으로 되돌려주므로, XST(Cross-Site Tracing) 공격을 통해 요청에 포함된 쿠키·인증 헤더 등 민감 정보가 응답으로 반사되어 탈취될 수 있다. TRACE 메서드는 운영 환경에서 실질적인 용도가 없으므로 비활성화하여야 한다.

4.9.2. 권고사항

□ 점검 방법

Copyright ⓒ 2022 By ngnicky All Rights Reserved.

점검 방법 TRACE 메서드의 허용 및 헤더 반사 여부를 확인한다

- TRACE 메서드로 요청 전송 후 응답 코드(200) 및 요청 헤더 반사(echo) 여부 확인
- curl -X TRACE, Burp Suite 등을 이용한 점검

□ 보안 설정 방법

불필요한 HTTP 메서드를 차단하여야 한다.

- Apache 설정(apache2.conf/httpd.conf)에 TraceEnable Off 적용하여 TRACE 메서드 비활성화
- 서비스에 불필요한 HTTP 메서드(PUT, DELETE, OPTIONS 등) 차단
- GET, POST 등 서비스에 필요한 메서드만 허용하도록 제한

4.10.1 중요 개인정보 노출 여부

4.10.1.1 취약점 개요

웹 페이지 소스코드, 에러 메시지, 응답 데이터 등에 이름, 주민등록번호, 연락처, 이메일 등 중요 개인정보가 암호화 또는 마스킹 처리 없이 노출될 경우 발생할 수 있는 취약점이다. 공격자가 페이지 소스 분석이나 응답 패킷 확인을 통해 개인정보를 수집할 수 있으며, 이를 통해 개인정보 유출 및 2차 피해로 이어지는 침해사고가 발생할 수 있다.

4.10.1.2. 권고사항

점검 방법

페이지 소스코드 및 응답 데이터 내 중요 개인정보가 평문으로 노출되어 있는지 확인한다.

- 브라우저 개발자 도구(F12) → Network/Elements 탭에서 응답 데이터 내 개인정보 포함 여부 확인
- 페이지 소스보기(Ctrl+U)를 통해 소스코드 내 개인정보 노출 여부 확인
- 프록시 툴을 이용하여 응답 패킷 내 개인정보 평문 포함 여부 확인
- 에러 발생 시 출력되는 메시지에 개인정보 포함 여부 확인

보안 설정 방법

중요 개인정보는 암호화 또는 마스킹 처리하여 노출되지 않도록 하고, 아래와 같은 보안 조치를

Copyright ⓒ 2022 By ngnicky All Rights Reserved.

적용하여야 한다.

- 주민등록번호, 연락처 등 중요 개인정보 출력 시 마스킹 처리 적용 (예: 990101-1******)
- 소스코드 및 응답 데이터 내 불필요한 개인정보 제거
- 에러 메시지에 개인정보가 포함되지 않도록 에러 처리 로직 구현
- 개인정보 저장 시 암호화 적용

4.10.2 쿠키 값 내 중요정보 유출 여부

4.10.2.1. 취약점 개요

사용자 인증 정보, 개인정보, 권한 정보 등 중요한 데이터가 암호화 없이 쿠키에 평문으로 저장되어 있을 경우 발생할 수 있는 취약점이다. 공격자가 브라우저 쿠키를 탈취하거나 네트워크 스니핑을 통해 쿠키 값을 획득할 경우 사용자의 민감한 정보가 그대로 노출될 수 있으며, 탈취한 정보를 이용한 계정 도용 및 개인정보 침해사고가 발생할 수 있다.

4.10.2.2 권고사항

점검 방법

브라우저 개발자 도구 또는 프록시 툴을 이용하여 쿠키 값 내 중요정보 포함 여부를 확인한다.

- 브라우저 개발자 도구(F12) → Application 탭 → Cookies에서 쿠키 값 내 중요정보 평문 저장 여부 확인
- Base64 등으로 인코딩된 쿠키 값을 디코딩하여 중요정보 포함 여부 확인
- 프록시 툴을 이용하여 요청/응답 헤더의 Set-Cookie 값 내 중요정보 포함 여부 분석
- 쿠키에 HttpOnly, Secure 속성 적용 여부 확인

보안 설정 방법

쿠키 내 중요정보 저장을 금지하고, 아래와 같은 보안 조치를 적용하여야 한다.

- 쿠키에 개인정보, 인증 정보 등 중요 데이터를 평문으로 저장하지 않도록 설계 변경
- 불가피하게 중요 데이터를 쿠키에 저장할 경우 암호화 적용
- 쿠키에 HttpOnly 속성 적용으로 JavaScript를 통한 쿠키 접근 차단
- 쿠키에 Secure 속성 적용으로 HTTPS 통신에서만 쿠키 전송되도록 설정
- 쿠키 만료 시간을 최소화하여 탈취 시 피해 최소화

Copyright ⓒ 2022 By ngnicky All Rights Reserved.

4.10.3 데이터베이스 관련 정보 유출 여부

4.10.3.1. 취약점 개요

웹 애플리케이션의 에러 페이지, 응답 메시지, 소스코드 주석 등에 데이터베이스 종류, 버전, 테이블명, 쿼리문, 접속 정보 등이 노출될 경우 발생할 수 있는 취약점이다. 공격자가 노출된 데이터베이스 정보를 분석하여 SQL Injection 등 추가적인 공격에 활용할 수 있으며, 이를 통해 데이터베이스 전체가 탈취되는 심각한 침해사고가 발생할 수 있다.

4.10.3.2. 권고사항

점검 방법

에러 메시지 및 소스코드 내 데이터베이스 관련 정보가 노출되는지 확인한다.

- 입력값에 특수문자(', ", ;) 삽입 후 에러 메시지에 DB 종류·버전·쿼리문 노출 여부 확인
- 존재하지 않는 페이지 접근 시 출력되는 에러 페이지에서 DB 관련 정보 노출 여부 확인
- 페이지 소스코드 및 JavaScript 파일 내 DB 접속 정보, 테이블명, 쿼리문 포함 여부 확인
- 응답 패킷 내 DB 관련 정보 포함 여부 확인

보안 설정 방법 데이터베이스 관련 정보가 외부에 노출되지 않도록 에러 처리 및 소스코드를 관리하고, 아래와 같은 보안 조치를 적용하여야 한다.

- 에러 발생 시 DB 관련 정보가 포함되지 않은 사용자 정의 에러 페이지로 대체
- 소스코드 및 주석 내 DB 접속 정보, 쿼리문 등 제거
- DB 접속 정보는 별도의 설정 파일로 분리하여 웹 루트 외부에 저장
- 웹 애플리케이션의 DB 계정은 최소 권한만 부여

4.10.4 중요정보 평문 전송

4.10.4.1. 취약점 개요

로그인 정보, 개인정보, 결제 정보 등 중요한 데이터가 SSL/TLS 암호화 통신이 아닌 HTTP 평문

Copyright ⓒ 2022 By ngnicky All Rights Reserved.

방식으로 전송될 경우 발생할 수 있는 취약점이다. 공격자가 네트워크 구간에서 패킷을 스니핑하여 전송 중인 중요 데이터를 그대로 획득할 수 있으며, 이를 통해 사용자 인증 정보 및 개인정보가 유출되는 침해사고가 발생할 수 있다.

4.10.4.2. 권고사항

점검 방법

프록시 툴 또는 패킷 캡처 도구를 이용하여 중요 데이터가 평문으로 전송되는지 확인한다.

- 브라우저 주소창에서 http://로 시작하는지 확인하여 HTTPS 미적용 여부 확인
- 브라우저 개발자 도구(F12) → Network 탭에서 로그인 요청 시 비밀번호 평문 전송 여부 확인
- Burp Suite 또는 Wireshark를 이용하여 전송 패킷 캡처 후 중요 데이터 평문 포함 여부 확인
- SSL/TLS 인증서 적용 여부 및 유효성 확인

보안 설정 방법

중요 데이터 전송 시 SSL/TLS 암호화 통신을 적용하고, 아래와 같은 보안 조치를 적용하여야 한다.

- 전체 웹 서비스에 SSL/TLS 인증서를 적용하여 HTTPS 통신 적용
- HTTP로 접근 시 HTTPS로 자동 리다이렉트 처리
- 최신 TLS 버전(TLS 1.2 이상) 사용 및 취약한 암호화 알고리즘 사용 제한
- HSTS(HTTP Strict Transport Security) 설정 적용

4.11. SQL Injection

4.11.1. 취약점 개요

SQL Injection은 사용자 입력값 검증이 미흡할 경우 발생하는 취약점으로 공격자가 특수문자 및 조작된 SQL 구문을 입력하여 인증 우회 또는 데이터 조회, 변조 등을 수행할 수 있다. 또한 SQL 오류 발생 시 예외처리가 적절히 구현되어 있지 않을 경우 비정상적인 인증 처리로 이어질 수 있다.

4.11.2. 권고사항

Copyright ⓒ 2022 By ngnicky All Rights Reserved.

점검 방법

사용자 입력란에 특수문자('), SQL 예약어(OR, AND, UNION 등)를 삽입하여 인증 우회가 가능한지 확인한다.

■ 점검 예시

✓ ID : ' Password : '

✓ ID : admin' or '1'='1 Password : admin

✓ ID : ' or 1=1 # Password : test

✓ ID : admin' -- Password : test

표 4-5 SQL Injection 테스트 입력값 예시

또한 SQL 오류 발생 시 시스템이 오류 메시지를 출력하는지 혹은 로그인 처리 로직이 정상적으로 차단되는지 확인한다.

보안 설정 방법

사용자 입력값을 SQL 질의문에 직접 연결하지 않도록 Prepared Statement(Parameterized Query)를 적용하여야 한다.

또한 로그인 처리 시 SQL 실행 결과에 대한 검증 로직 및 예외처리를 구현하여 비정상적인 Result 값이 반환될 경우 반드시 로그인 실패 처리하도록 구성하여야 한다.

■ 사용자 입력값에 대한 필터링 및 검증 수행

■ 특수문자 및 SQL 예약어 입력 제한

■ Prepared Statement 사용을 통한 동적 SQL 차단

■ SQL 오류 발생 시 예외처리 수행 및 인증 차단

■ DB 오류 메시지가 사용자에게 노출되지 않도록 설정

■ 웹 서버 및 DBMS의 에러 로그 관리 강화

Copyright ⓒ 2022 By ngnicky All Rights Reserved.

표 4-6 SQL Injection 보안 설정 방법

4.12. 파일 업로드 취약점

4.12.1. 취약점 개요

파일 업로드 기능이 클라이언트 측 검증에만 의존할 경우 공격자가 요청 및 응답 데이터를 조작하여 제한을 우회할 수 있는 취약점이다. 특히 PHP, JSP, ASP 등의 서버 스크립트 파일 업로드가 가능할 경우 서버 장악으로 이어질 수 있다.

4.12.2. 권고사항

점검 방법

파일 업로드 기능에서 서버 스크립트 파일 업로드가 가능한지 확인하고 Burp Suite 등의 프록시 도구를 이용하여 검증 로직 우회 여부를 점검한다.

- ■ 차단 권고 확장자
  - ✓ .php
  - ✓ .php3
  - ✓ .php5
  - ✓ .phtml
  - ✓ .phar
  - ✓ .asp
  - ✓ .aspx
  - ✓ .jsp
  - ✓ .cgi
  - ✓ .pl
  - ✓ .py
  - ✓ .sh
  - ✓ .bat
  - ✓ .cmd

Copyright ⓒ 2022 By ngnicky All Rights Reserved.

✓ .exe ✓ .dll ✓ .htaccess

표 4-7 파일 업로드 취약점 점검 방법

보안 설정 방법

파일 업로드 제한 기능은 반드시 서버 측(Server-Side)에서 검증되어야 하며, 클라이언트 측(JavaScript) 검증만으로 업로드를 제한해서는 안 된다.

또한 업로드 가능한 확장자를 화이트리스트 방식으로 제한하고 업로드 디렉터리 내 스크립트 실행을 차단하여야 한다.

■ 서버 측 확장자 검증 수행 ■ MIME Type 및 파일 시그니처 검증 수행 ■ 업로드 파일명 난수화 처리 ■ 업로드 디렉터리 실행 권한 제거 ■ 웹 루트 외부 경로에 파일 저장 ■ 클라이언트 측 검증 의존 제거

표 4-8 파일 업로드 취약점 보안 설정 방법

Copyright ⓒ 2022 By ngnicky All Rights Reserved.